GDPR | STUDIO MEDICO

Privacy Studio

Manuale d'uso e di conformità



Dall'installazione all'uso quotidiano

Registro dei trattamenti, informative e consegne, richieste degli interessati, violazioni dei dati, conservazione, backup e ripristino, con i riferimenti al Regolamento (UE) 2016/679 e al Codice in materia di protezione dei dati personali.

VERSIONE 0.9 - BOZZA PER REVISIONE

Novembre 2026 - Documento per il titolare del trattamento. Non è una consulenza legale.

Indice

Avvertenze e modo di lettura . . . 5

Che cosa è e che cosa non è questo documento . . . 5

Come sono segnalati i punti da verificare . . . 5

Stato del programma . . . 5

0. Gli adempimenti del medico libero professionista . . . 6

0.1 Il punto di partenza: chi è il medico per il GDPR . . . 6

0.2 Gli adempimenti in una pagina . . . 8

0.3 Gli adempimenti, uno per uno . . . 8

0.4 I documenti che lo studio dovrebbe avere . . . 14

0.5 Da dove cominciare e come mantenersi in regola . . . 15

0.6 Dove Privacy Studio aiuta, e dove no . . . 16

0.7 Che cosa si rischia se non si è in regola . . . 16

1. A che cosa serve Privacy Studio . . . 17

1.1 Lo scopo . . . 17

1.2 Le sette funzioni . . . 17

1.3 Che cosa Privacy Studio non fa . . . 17

1.4 I principi di funzionamento . . . 18

2. Il quadro normativo in sintesi . . . 19

2.1 Le fonti . . . 19

2.2 Perché non serve il consenso per curare, e quando serve . . . 19

2.3 Gli obblighi che il programma non copre da solo . . . 20

3. Prima di installare . . . 21

3.1 Requisiti . . . 21

3.2 Sicurezza del computer . . . 21

3.3 Che cosa preparare prima di iniziare . . . 22

4. Installazione . . . 23

4.0 Installazione guidata (consigliata) . . . 23

Installazione manuale (riferimento tecnico) . . . 23

4.1 Installare i componenti (manuale) . . . 23

4.2 Tenere il database chiuso verso la rete . . . 24

4.3 Creare il database e i due ruoli . . . 24
4.4 Dire al programma come raggiungere il database . . . 24
4.5 Cartelle dei backup e delle eliminazioni . . . 25
4.6 Verifica finale dell'installazione . . . 25

5. Primo avvio e configurazione . . . 26
5.1 Prima configurazione dello studio . . . 26
5.2 Accesso quotidiano . . . 27
5.3 Le chiavi di recupero: da fare subito . . . 28

6. Uso del programma . . . 30
6.1 La finestra principale . . . 30
6.2 Pazienti (anagrafica degli interessati) . . . 32
6.3 Informative e consegne . . . 34
6.4 Registro dei trattamenti . . . 38
6.5 Richieste degli interessati . . . 41
6.6 Violazioni dei dati (incidenti) . . . 44
6.7 Conservazione e eliminazione . . . 46
6.8 Backup e chiavi . . . 48

7. Procedure operative . . . 50
7.1 Che cosa fare, e quando . . . 50
7.2 Una richiesta di un paziente, dall'inizio alla fine . . . 50
7.3 Una violazione dei dati, dalla scoperta alla chiusura . . . 50
7.4 Ripristino dopo un guasto o su un nuovo computer . . . 51

8. Sicurezza e responsabilità . . . 52
8.1 Che cosa fa il programma per la sicurezza . . . 52
8.2 Limiti dichiarati . . . 52
8.3 Che cosa resta al titolare . . . 53

9. Punti da esaminare . . . 54

10. Stato delle funzioni e condizioni di rilascio . . . 55
10.1 Che cosa è disponibile oggi . . . 56
10.2 Condizioni prima di usare dati reali . . . 56

Appendice A - Glossario . . . 57

Appendice B - Esempi di calcolo dei termini 58

Appendice C - Lista di controllo per l'avvio 59

Appendice D - Riferimenti normativi e documenti 60

Norme citate 60

Documenti tecnici del progetto 60

Registro delle modifiche del manuale 60

Avvertenze e modo di lettura

Questo manuale accompagna il titolare del trattamento, cioè il medico, dall'installazione di Privacy Studio all'uso delle sue funzioni, collegando ogni funzione alle norme che la motivano. È scritto per chi non è un tecnico: dove serve un'operazione informatica, lo si dice e si indica a chi chiederla.

Che cosa è e che cosa non è questo documento

- **È** una guida operativa: spiega che cosa fa il programma, come si usa e quali norme ne sono alla base.
- **Non è** una consulenza legale né un parere di conformità. Il programma aiuta a documentare e a rispettare le scadenze; **non certifica** che lo studio sia conforme al GDPR e non decide al posto del titolare.
- **Non sostituisce** il consulente privacy, il commercialista o l'Ordine professionale sui punti in cui la norma lascia margini di scelta.

Come sono segnalati i punti da verificare

Le norme sono citate nella forma in cui chi scrive le conosce alla data del documento. La legge cambia e le autorità emanano nuovi provvedimenti: prima di basarsi su una citazione per una decisione importante, controllarne il testo vigente. Nel manuale compaiono quattro tipi di riquadro:

RIFERIMENTO NORMATIVO
La norma (articolo del GDPR, del Codice privacy, ecc.) da cui nasce la funzione o l'obbligo.

DA ESAMINARE
Un punto **di cui non si ha certezza**, interpretabile o rimesso al titolare e al consulente. Sono tutti raccolti nel capitolo 9, con chi dovrebbe decidere.

ATTENZIONE
Un rischio concreto: operazione irreversibile, scadenza, possibile perdita di dati.

CONSIGLIO
Una buona pratica, non un obbligo.

Stato del programma

ATTENZIONE
Privacy Studio è in fase di **pre-rilascio**. È stato provato con dati sintetici (inventati) e con test automatici, non ancora con dati reali né su un computer Windows "pulito" come quello dello studio.
Non usarlo con dati reali dei pazienti finché non sono soddisfatte le condizioni di rilascio elencate nel capitolo 10 (tra le altre: prova di ripristino su una macchina pulita, decisione sulla gestione delle chiavi, conferma della regola dei termini).

NOTA
Il capitolo 0 vale per ogni medico, a prescindere dal programma; il capitolo 10 elenca che cosa il programma fa e che cosa manca. Le schermate riprodotte usano **dati inventati** (studio, persone, richieste e incidenti fittizi); i valori che vi compaiono, per esempio le durate di conservazione, sono esempi e **non indicazioni**.

0. Gli adempimenti del medico libero professionista

Questo capitolo è indipendente dal programma: descrive gli adempimenti che il Regolamento (UE) 2016/679 (GDPR) e il Codice privacy pongono al medico che esercita in proprio, in ordine di priorità e con i riferimenti normativi. Privacy Studio ne copre una parte (§ 0.6); il resto resta al titolare. Non esiste un «bollino» di conformità: la legge chiede di adottare **misure adeguate** al rischio e di essere in grado di **dimostrarlo**.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 24, par. 1; art. 5, par. 2 (responsabilizzazione)
Il titolare mette in atto misure tecniche e organizzative adeguate per garantire, ed essere in grado di dimostrare, che il trattamento è effettuato conformemente al Regolamento, tenuto conto della natura, dell'ambito, del contesto e delle finalità del trattamento e dei rischi per i diritti e le libertà delle persone. Le misure sono riesaminate e aggiornate se necessario.

DA ESAMINARE
Questo capitolo è una **sintesi divulgativa**, non un parere legale. Le norme sono citate come note alla data del manuale; i provvedimenti del Garante e le linee guida europee cambiano. I punti in cui la norma lascia margini di scelta, o di cui chi scrive non ha certezza, sono segnalati in questi riquadri e raccolti nel capitolo 9.

0.1 Il punto di partenza: chi è il medico per il GDPR

Il medico che decide **quali dati dei pazienti raccogliere, perché e come** è titolare del trattamento. Il suo ruolo concreto dipende da come lavora:

Situazione	Ruolo di norma	Da tenere presente
Studio proprio, esercizio individuale	**Titolare autonomo** dei dati dei propri pazienti (art. 4, n. 7).	Tutti gli adempimenti di questo capitolo ricadono sul medico.
Medico di medicina generale o pediatra di libera scelta convenzionato	Titolare per i propri assistiti.	Il Codice ha una norma specifica sull'informativa (art. 78). I dati inseriti nei sistemi regionali o nazionali (prescrizioni, anagrafe assistiti) seguono le regole di quei sistemi: **ruolo da verificare**.
Studio associato, medicina di gruppo, segreteria o archivio in comune	Ciascun medico titolare per i propri pazienti, con un **responsabile** comune (la segreteria) oppure **contitolarità** (art. 26).	Serve un accordo scritto che dica chi fa che cosa e chi risponde agli interessati.
Medico che esercita in una struttura (ambulatorio, poliambulatorio, clinica)	Di norma **titolare è la struttura** per i dati trattati con i suoi mezzi; il medico può essere persona autorizzata o titolare autonomo per alcuni dati.	Dipende dal contratto e da chi decide gli strumenti: **da esaminare caso per caso**.
Medico competente (medicina del lavoro)	Titolare autonomo delle cartelle sanitarie e di rischio dei lavoratori, secondo la disciplina specifica (D.Lgs. 81/2008).	Regole proprie su conservazione e comunicazioni al datore di lavoro: **da esaminare**.
Telemedicina o piattaforme online	La piattaforma può essere **responsabile** (art. 28) o **contitolare** (art. 26).	Verificare contratto, luogo dei dati e trasferimenti fuori dall'Unione (§ 0.3.7).

DA ESAMINARE
La qualificazione del ruolo (titolare autonomo, contitolare, responsabile, persona autorizzata) non è automatica e cambia gli adempimenti. In presenza di una struttura, di un'associazione o di una piattaforma, va stabilita **con il consulente**, leggendo i contratti.

Che dati sono in gioco

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 4, n. 15 e art. 9, par. 1
«Dati relativi alla salute» sono i dati personali attinenti alla salute fisica o mentale di una persona fisica, compresa la prestazione di servizi di assistenza sanitaria, che rivelano informazioni relative al suo stato di salute. Sono una **categoria particolare** di dati: il loro trattamento è vietato salvo le eccezioni dell'art. 9, par. 2.

Rientrano non solo diagnosi, terapie e referti, ma anche il semplice fatto che una persona sia paziente dello studio, gli appuntamenti, le prescrizioni e i certificati. Ci sono poi i dati «ordinari»: anagrafica, recapiti, fatturazione, e quelli di collaboratori e fornitori.

Segreto professionale e consensi: due cose da non confondere

- **Segreto professionale**: il medico è già tenuto alla riservatezza (art. 622 del codice penale; Codice di deontologia medica, artt. 10 e 11 nel testo del 2014, da verificare nella versione vigente). La disciplina privacy si **aggiunge** al segreto, non lo sostituisce; l'art. 9, par. 3 GDPR lo richiama espressamente.
- **Consenso informato alle cure** (legge 22 dicembre 2017, n. 219): riguarda il trattamento sanitario, non il trattamento dei dati. Per curare il paziente **non serve** un consenso privacy (§ 2.2); serve invece, di norma, il consenso alle cure. Sono due documenti e due basi diverse.

0.2 Gli adempimenti in una pagina

N.	Adempimento	Norma	Quando	Nel manuale
1	Mappare i trattamenti e i dati	Artt. 5, 30	Sempre: è la base di tutto	§ 0.3.1, 6.4
2	Individuare finalità e basi giuridiche	Artt. 6, 9	Sempre	§ 0.3.2, 2.2
3	Informativa ai pazienti	Artt. 12-14; art. 78 Codice	Sempre	§ 0.3.3, 6.3
4	Registro dei trattamenti	Art. 30	Sempre (par. 5: l'esenzione non vale)	§ 6.4
5	Misure di sicurezza	Artt. 25, 32	Sempre	§ 0.3.5, cap. 3 e 8
6	Designare le persone autorizzate	Artt. 29, 32 par. 4; art. 2-quaterdecies	Se ci sono collaboratori, sostituti, tirocinanti	§ 0.3.6
7	Nominare i responsabili; gestire contitolari e trasferimenti	Artt. 26, 28; capo V	Se fornitori trattano dati per conto dello studio	§ 0.3.7
8	Procedura per i diritti degli interessati	Artt. 12, 15-22; art. 2-terdecies	Sempre (la procedura); le richieste, quando arrivano	§ 0.3.8, 6.5
9	Procedura e registro delle violazioni	Artt. 33, 34	Sempre (la procedura e il registro)	§ 0.3.9, 6.6
10	Conservazione e cancellazione	Art. 5 par. 1 lett. e); artt. 17, 30	Sempre	§ 0.3.10, 6.7
11	Valutare DPIA e DPO, e documentare la valutazione	Artt. 35, 37	Da valutare sempre; obbligo solo in certi casi	§ 0.3.11
12	Situazioni particolari (consensi, telemedicina, fascicolo sanitario, sito web, videosorveglianza, minori)	Vari	Se ricorrono	§ 0.3.12
13	Formazione e verifica periodica	Artt. 24, 32 par. 4	Sempre	§ 0.5

0.3 Gli adempimenti, uno per uno

0.3.1 Sapere che cosa si tratta: la mappa dei trattamenti

- Elencare **quali dati** si raccolgono (anagrafici, contatto, salute, fatturazione), **da chi** (paziente, familiari, altri medici, laboratori, ASL), **dove** stanno (gestionale, cartelle cartacee, computer, telefono, posta, cloud, supporti esterni) e **chi può vederli**.
- Contare anche i canali «informali»: messaggi su WhatsApp, foto di referti sul telefono, email con allegati, agende di carta, fogli di calcolo.
- Per ogni trattamento chiedersi: serve davvero questo dato? (**minimizzazione**) È esatto e aggiornato? Per quanto tempo lo tengo?

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 5, par. 1, lett. c), d), e), f)
I dati personali sono adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità (minimizzazione); esatti e, se necessario, aggiornati; conservati per un arco di tempo non superiore a quello necessario (limitazione della conservazione); trattati in modo da garantirne un'adeguata sicurezza (integrità e riservatezza).

La mappa è il materiale da cui nascono il registro (§ 6.4), l'informativa e la valutazione dei rischi. Senza, tutto il resto è costruito sulla sabbia.

0.3.2 Perché si può trattare quel dato: finalità e basi giuridiche

Ogni trattamento ha una **finalità** dichiarata e una **base giuridica** (art. 6); per i dati sulla salute serve in più una **condizione dell'art. 9, par. 2**. Per un medico le combinazioni tipiche sono:

Attività	Base art. 6	Condizione art. 9 (dati sulla salute)
Visita, diagnosi, terapia, gestione dell'agenda e dei documenti clinici	Lett. b): esecuzione del contratto con il paziente (o misure precontrattuali)	Par. 2, lett. h) con par. 3: finalità di cura, da parte di un professionista tenuto al segreto
Fatturazione, adempimenti fiscali e contabili	Lett. c): obbligo legale	Di norma non servono dati sanitari analitici; se ci sono, lett. h) o lett. f)
Comunicazioni obbligatorie (certificati, segnalazioni di legge, sistemi prescrittivi)	Lett. c): obbligo legale	Lett. h) o i) (sanità pubblica), secondo la norma che impone la comunicazione
Difesa in un contenzioso o in una richiesta di risarcimento	Lett. f) (legittimo interesse) o lett. c)	Par. 2, lett. f): accertare, esercitare o difendere un diritto in sede giudiziaria
Comunicazioni promozionali, newsletter, ricerca, alcuni servizi opzionali	Lett. a): **consenso**	Par. 2, lett. a): consenso esplicito (per ricerca possono esistere altre regole)

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 9, par. 2, lett. h) e par. 3; art. 6, par. 1
Il trattamento di dati relativi alla salute è consentito quando è necessario per finalità di medicina preventiva, diagnosi, assistenza o terapia sanitaria, sulla base del diritto dell'Unione o degli Stati membri o di un contratto con un professionista della sanità, se i dati sono trattati da o sotto la responsabilità di un professionista soggetto al segreto professionale. Il Garante ha chiarito (provvedimento del 7 marzo 2019) che per le finalità di cura **non occorre il consenso** dell'interessato.

DA ESAMINARE
L'abbinamento tra ogni attività dello studio e la base giuridica è una **valutazione del titolare** e va scritta (nel registro, § 6.4). Il **consenso** è la base giusta solo per ciò che non è necessario alla cura; non va chiesto «per sicurezza» dove una base diversa si applica, perché un consenso non libero o non revocabile è inefficace e genera confusione. Quali trattamenti dello studio richiedano davvero un consenso va verificato con il consulente.

0.3.3 L'informativa ai pazienti

- Va data **prima o al momento** della raccolta dei dati (art. 13, par. 1), in forma concisa, trasparente, intelligibile e accessibile, con linguaggio semplice e chiaro, **anche per minori** (art. 12, par. 1).

- Contenuto: identità e contatti del titolare (e del DPO, se c'è); finalità e base giuridica; destinatari o categorie di destinatari; eventuali trasferimenti fuori dall'UE; **periodo di conservazione** o criteri; diritti dell'interessato e diritto di reclamo al Garante; se il conferimento è obbligatorio; eventuali processi decisionali automatizzati (art. 13, par. 1 e 2).
- Se i dati arrivano da altri (un altro medico, un familiare, un laboratorio) l'informativa va data anche all'interessato, **entro un termine ragionevole e al più tardi entro un mese** (art. 14, par. 3), salvo le eccezioni dell'art. 14, par. 5.
- Va resa **disponibile in studio** (sala d'attesa, consegna) e, se esiste, **sul sito**. Conviene darla anche al paziente nuovo, e riconsegnarla se cambia in modo rilevante.
- Il medico deve poter **dimostrare** di averla data: Privacy Studio registra le consegne (§ 6.3). La firma del paziente non è richiesta dalla legge per l'informativa.

RIFERIMENTO NORMATIVO - D.Lgs. 196/2003, art. 78
Per il medico di medicina generale e il pediatra di libera scelta il Codice contiene una disposizione specifica sulle informazioni da dare ai pazienti, che permette di fornire le informazioni in forma semplificata per più trattamenti.

DA ESAMINARE
Il contenuto esatto dell'informativa, l'eventuale forma a più livelli (breve in sala d'attesa e completa a richiesta o sul sito) e l'applicabilità dell'art. 78 vanno decisi con il consulente. Il programma fornisce uno **schema**, non un testo valido.

0.3.4 Il registro dei trattamenti

È obbligatorio per lo studio medico: l'esenzione per organizzazioni con meno di 250 dipendenti **non si applica** perché i trattamenti non sono occasionali e includono categorie particolari di dati (art. 30, par. 5). Contenuto e funzionamento sono nel § 6.4. Va tenuto in forma scritta (anche elettronica) e mostrato al Garante se lo chiede.

0.3.5 La sicurezza dei dati

Il vecchio elenco di «misure minime» (allegato B del Codice) non esiste più: dal 2018 la sicurezza si valuta **caso per caso**, in base al rischio (art. 32). Per uno studio medico, significa almeno:

Area	Misure da mettere in atto o verificare
Accesso ai locali e alle cartelle cartacee	Armadi chiusi a chiave; chi può entrare nello studio e vedere agende e schermi; riservatezza in sala d'attesa e al telefono.
Computer e programmi	Account personali con password robuste; blocco schermo automatico; aggiornamenti automatici; antivirus; **cifratura del disco**; nessun uso promiscuo del computer; software regolarmente licenziato.
Rete e posta	Firewall; wi-fi dello studio protetto e separato da quello degli ospiti; **niente referti inviati per email non protetta** (usare PEC o allegati cifrati, o altri canali sicuri concordati).
Telefoni e messaggistica	Evitare di conservare dati sanitari nelle chat e nelle foto del telefono personale; se inevitabile, protezione del dispositivo e regole scritte; mai l'invio a persone non verificate.
Copie di sicurezza	**Backup** regolari, cifrati, con una copia fuori dallo studio, e prova periodica di ripristino (art. 32, par. 1, lett. c) e d)).

Area	Misure da mettere in atto o verificare
Supporti e dismissione	Chiavette e dischi rimovibili cifrati o evitati; distruzione sicura di carta e supporti non più necessari; cancellazione sicura dei dati prima di dismettere o riparare un computer.
Persone	Istruzioni scritte e formazione a chi lavora nello studio (§ 0.3.6); vincolo di riservatezza.
Verifica	Riesame periodico delle misure e prova che funzionano (art. 32, par. 1, lett. d)).

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 32, par. 1 e 2; art. 25 (protezione dei dati fin dalla progettazione e per impostazione predefinita)
Tenuto conto dello stato dell'arte, dei costi, della natura e delle finalità, il titolare mette in atto misure adeguate al rischio, che comprendono, se del caso: pseudonimizzazione e cifratura; riservatezza, integrità, disponibilità e resilienza dei sistemi; capacità di ripristinare tempestivamente i dati; una procedura per provare e valutare regolarmente l'efficacia delle misure. Si tiene conto in particolare dei rischi di distruzione, perdita, modifica, divulgazione o accesso non autorizzati.

DA ESAMINARE
L'art. 2-septies del Codice prevede **misure di garanzia** per il trattamento di dati relativi alla salute, da individuare con provvedimento del Garante: stato e contenuto vigenti vanno verificati. Quanto sia «adeguata» una singola misura (per esempio la cifratura dei campi oltre a quella del disco) è una valutazione tecnica da documentare.

0.3.6 Chi lavora nello studio: le persone autorizzate

- Chiunque tratti dati sotto l'autorità del medico (segretaria, collaboratori, sostituti, tirocinanti, personale delle pulizie se può accedere agli archivi) deve essere **istruito** e, nella prassi consigliata, **designato per iscritto** con l'indicazione dei dati e dei compiti.
- Le istruzioni coprono: accesso solo a ciò che serve, password personali, divieto di copiare dati su dispositivi privati, comportamento al telefono e in sala d'attesa, che cosa fare in caso di incidente (§ 7.3), obbligo di riservatezza anche dopo la fine del rapporto.
- La **formazione** va fatta e documentata (data, partecipanti, argomenti), e ripetuta periodicamente e quando cambia qualcosa.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 29 e art. 32, par. 4; D.Lgs. 196/2003, art. 2-quaterdecies
Chiunque agisca sotto l'autorità del titolare e abbia accesso a dati personali non può trattare tali dati se non è istruito in tal senso dal titolare. Il titolare può prevedere che compiti e funzioni siano attribuiti a persone fisiche espressamente designate, che operano sotto la sua autorità.

0.3.7 Fornitori, altri professionisti, trasferimenti

Chi tratta dati **per conto** del medico è responsabile del trattamento e serve un contratto o altro atto giuridico scritto con il contenuto dell'art. 28, par. 3 (istruzioni documentate, riservatezza, misure di sicurezza, sub-fornitori, assistenza per diritti e violazioni, cancellazione o restituzione a fine rapporto, audit). Casi tipici:

Soggetto	Ruolo di norma	Da fare
Fornitore del gestionale, del cloud, dell'hosting, della posta	Responsabile (art. 28)	Contratto con le clausole dell'art. 28; verificare dove stanno i dati e i sub-fornitori.
Assistenza informatica che può accedere ai dati	Responsabile (o persona autorizzata se lavora sotto l'autorità del medico)	Nomina scritta; accessi limitati e tracciati.

Soggetto	Ruolo di norma	Da fare
Laboratori, centri diagnostici, specialisti a cui si invia il paziente	Di norma titolari autonomi	Nessuna nomina; ma il flusso dei dati va indicato nell'informativa.
Commercialista, consulente del lavoro	Dipende dal servizio: titolare autonomo per gli obblighi di legge propri, responsabile per servizi affidati	Verificare caso per caso e documentare.
Altro medico in associazione o sostituto	Contitolare, titolare autonomo o persona autorizzata	Accordo scritto (art. 26) o designazione.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 28, par. 1 e 3; art. 26 (contitolari)
Il trattamento da parte di un responsabile è disciplinato da un contratto o altro atto giuridico che vincola il responsabile al titolare e stipula materia, durata, natura e finalità, tipo di dati, categorie di interessati, obblighi e diritti del titolare. Il titolare ricorre unicamente a responsabili che presentino garanzie sufficienti.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, artt. 44-49 (capo V)
Il trasferimento di dati personali verso un paese terzo (fuori dallo Spazio economico europeo) è ammesso solo con una decisione di adeguatezza della Commissione o con garanzie adeguate (per esempio clausole contrattuali tipo) o in casi specifici.

DA ESAMINARE
Molti servizi in cloud, di posta e di videochiamata hanno sedi o sub-fornitori fuori dall'Unione (in particolare negli Stati Uniti). La validità del trasferimento dipende dalle decisioni di adeguatezza (tra cui quella del 2023 per le imprese statunitensi certificate) e dalle garanzie contrattuali, e può cambiare. **Da verificare con il consulente** per ogni servizio che contiene dati sanitari.

0.3.8 I diritti dei pazienti: la procedura

- Preparare una **procedura** (anche di una pagina) che dica a chi arrivano le richieste (email o PEC dello studio), chi le gestisce, come si verifica l'identità del richiedente, come si registrano, come si risponde.
- **Termine**: senza ingiustificato ritardo e al più tardi entro un mese dal ricevimento; prorogabile di due mesi per complessità o numero di richieste, con comunicazione dei motivi entro il primo mese (art. 12, par. 3). Il programma calcola la scadenza (§ 6.5); la regola di calcolo va confermata (cap. 9, punto 2).
- **Accesso** (art. 15): conferma del trattamento, copia dei dati, informazioni su finalità, destinatari, conservazione; la copia della documentazione clinica ha regole e tempi propri da verificare.
- **Rettifica** (art. 16), **cancellazione** (art. 17: spesso non applicabile ai dati clinici, per obblighi di legge e difesa in giudizio, par. 3), **limitazione** (art. 18), **portabilità** (art. 20), **opposizione** (art. 21).
- Le informazioni sono gratuite; si può rifiutare o chiedere un contributo solo per richieste manifestamente infondate o eccessive, con motivazione (art. 12, par. 5). In caso di dubbio ragionevole sull'identità si chiedono informazioni supplementari (art. 12, par. 6).
- Per i **defunti** i diritti possono essere esercitati da chi ha un interesse proprio o agisce a tutela dell'interessato o per ragioni familiari meritevoli di protezione (art. 2-terdecies Codice).

DA ESAMINARE
Il rapporto tra il termine ordinario dell'art. 12 e le disposizioni specifiche sull'accesso alla documentazione sanitaria (per esempio l'art. 4 della legge 24/2017) e, più in generale, **che cosa si consegna e in che forma** a un paziente che chiede la propria cartella, va chiarito con il consulente.

0.3.9 Le violazioni dei dati

Una **violazione** è ogni evento di sicurezza che porta a distruzione, perdita, modifica, divulgazione o accesso non autorizzati ai dati (art. 4, n. 12), accidentale o illecito. Negli studi medici le più frequenti sono:

- smarrimento o furto di computer, telefono, chiavetta, borsa del medico;
- email o messaggio con un referto inviato alla persona sbagliata, o in chiaro a un indirizzo sbagliato;
- **ransomware** o guasto che rende i dati indisponibili (anche la sola indisponibilità è una violazione);
- accesso non autorizzato a un account, a un programma o alla posta;
- documenti cartacei lasciati incustoditi o smaltiti senza distruzione.
- Avere una **procedura scritta** (chi decide, chi avvisa, a chi) e **registrare ogni violazione**, anche se non notificata (art. 33, par. 5).
- **Notificare al Garante senza ingiustificato ritardo e, ove possibile, entro 72 ore** da quando se ne è venuti a conoscenza, a meno che sia improbabile un rischio per i diritti e le libertà degli interessati (art. 33, par. 1). Oltre le 72 ore vanno indicati i motivi del ritardo.
- **Comunicare agli interessati**, senza ingiustificato ritardo, se il rischio è elevato (art. 34), salvo le eccezioni del par. 3.

Procedura operativa nel § 7.3; registrazione nel programma al § 6.6.

0.3.10 Conservazione e cancellazione

- Per ogni tipo di dato **stabilire e scrivere** per quanto tempo si conserva e perché (art. 5, par. 1, lett. e); art. 30, par. 1, lett. f)); il periodo o i criteri vanno indicati anche nell'informativa (art. 13, par. 2, lett. a)).
- A fine periodo i dati vanno **cancellati o resi anonimi**, con modalità sicure, e la cancellazione va documentata.
- Documentazione amministrativa e contabile: scritture contabili generalmente per **dieci anni** (art. 2220 c.c.); altri documenti fiscali secondo la normativa tributaria.

> DA ESAMINARE
> **La durata di conservazione della documentazione clinica dello studio individuale non è fissata da una regola unica e semplice**: dipende da obblighi di legge, esigenze di difesa in giudizio, indicazioni dell'Ordine e regole regionali; per le cartelle cliniche delle strutture sanitarie la prassi è molto lunga o illimitata. Va deciso e motivato per iscritto con il consulente. Il programma non tiene la cartella clinica e non propone durate.

0.3.11 Valutazione d'impatto e responsabile della protezione dei dati

- **DPIA** (art. 35): obbligatoria quando un trattamento può presentare un rischio elevato, in particolare per trattamenti **su larga scala** di categorie particolari di dati. Il considerando 91 precisa che il trattamento dei dati dei pazienti da parte di un **singolo professionista sanitario** non va considerato su larga scala.
- **DPO** (art. 37): obbligatorio, tra l'altro, se l'attività principale consiste in trattamenti su larga scala di categorie particolari di dati. Il Garante ha indicato nelle sue FAQ che il singolo professionista sanitario in libera professione a titolo individuale **non** è, di regola, tenuto a designarlo; le linee guida europee sul DPO (WP 243) ragionano allo stesso modo.
- **Anche se non obbligatori**, conviene **scrivere la valutazione** (una pagina): perché si ritiene che DPIA e DPO non servano, in base a quali elementi dello studio (un solo medico, numero di pazienti, assenza di tecnologie innovative).

DA ESAMINARE

La conclusione cambia con le dimensioni e l'organizzazione dello studio: più medici, grande numero di pazienti, **telemedicina o strumenti innovativi** (applicazioni, intelligenza artificiale, dispositivi connessi), videosorveglianza. Il Garante ha pubblicato un elenco di trattamenti per cui la DPIA è richiesta (provvedimento dell'11 ottobre 2018): **da consultare con il consulente** prima di concludere.

0.3.12 Situazioni particolari

Situazione	Che cosa considerare
Minori e persone sotto tutela	L'informativa va dalla parte di chi esercita la responsabilità genitoriale o la tutela, con linguaggio adatto al minore; documentare i poteri di chi accompagna il paziente. Il consenso del minore per i servizi online ha limiti d'età propri (art. 8 GDPR; art. 2-quinquies Codice), diversi dal consenso alle cure.
Telemedicina, videovisite, app	Piattaforma come responsabile o contitolare; sicurezza del collegamento; informativa specifica; verifica dei trasferimenti fuori UE; possibile DPIA. Le regole sanitarie sulla telemedicina sono distinte da quelle privacy.
Fascicolo sanitario elettronico e sistemi regionali	Disciplina specifica, con regole proprie sul consenso all'alimentazione e alla consultazione; seguire le istruzioni della Regione e le regole sul FSE (art. 12 D.L. 179/2012 e decreti attuativi): **da verificare**.
Sito web dello studio	Informativa sul sito; cookie e strumenti di tracciamento secondo le linee guida del Garante (giugno 2021); moduli di contatto che raccolgono dati; non pubblicare dati o immagini di pazienti senza una base valida.
Comunicazioni promozionali, recensioni, social	Il marketing diretto richiede consenso (art. 130 Codice per le comunicazioni elettroniche); mai usare dati sanitari a fini promozionali senza base valida; attenzione a foto e storie dei pazienti.
Videosorveglianza	Se presente: cartelli informativi, base giuridica, limiti su riprese di aree dove si trattano dati sanitari, tempi di conservazione delle immagini; le linee guida europee in materia (3/2019) sono il riferimento.
Dipendenti e collaboratori	Ulteriori informative (lavoratori), registro, accessi; disciplina del lavoro sui controlli a distanza.

0.4 I documenti che lo studio dovrebbe avere

Al termine del percorso, in uno stesso luogo (cartella o archivio), lo studio dovrebbe poter mostrare:

Documento	Contenuto	In Privacy Studio
Registro dei trattamenti	Attività, finalità, basi giuridiche, categorie, destinatari, conservazione, misure	Sì (parziale, § 6.4)
Informativa ai pazienti	Testo approvato, versione e data; prova della consegna	Sì (§ 6.3)
Designazioni delle persone autorizzate	Nomi, compiti, istruzioni, formazione ricevuta	No
Elenco dei fornitori e contratti con i responsabili	Chi tratta dati per conto dello studio e con quale atto	No (previsto)
Procedura per i diritti e registro delle richieste	Chi fa che cosa; richieste, esiti, tempi	Sì (§ 6.5)

Documento	Contenuto	In Privacy Studio
Procedura per le violazioni e registro delle violazioni	Istruzioni, ruoli, registro anche delle non notificate	Sì (§ 6.6)
Valutazione dei rischi e delle misure di sicurezza	Misure in atto, rischi residui, piano di miglioramento	In parte (backup, accesso)
Regole di conservazione e registro delle eliminazioni	Durate, motivazioni, eliminazioni eseguite	Sì (§ 6.7)
Valutazione su DPO e DPIA	Perché si ritengono non necessari, o i documenti se necessari	No
Documentazione della formazione	Date, partecipanti, argomenti	No

0.5 Da dove cominciare e come mantenersi in regola

Un ordine ragionevole

1. **Prima settimana**: mappare trattamenti e dati; decidere ruoli e fornitori; mettere in sicurezza il minimo urgente (disco cifrato, aggiornamenti, backup su supporto separato).
2. **Primo mese**: scrivere basi giuridiche e registro; redigere l'informativa e iniziare a consegnarla; designare le persone autorizzate; preparare le due procedure (diritti e violazioni).
3. **Entro tre mesi**: contratti con i responsabili; decisioni su conservazione, DPO e DPIA; formazione; prova di ripristino del backup.

Mantenimento

- **Ogni anno**: riesame del registro, dell'informativa, delle durate di conservazione, delle misure di sicurezza e dell'elenco dei fornitori; ripetere la formazione.
- **Quando cambia qualcosa** (nuovo software, nuovo fornitore, nuova sede, nuovo collaboratore, nuovo servizio): aggiornare registro e informativa e rivalutare i rischi.
- **Dopo ogni violazione o richiesta difficile**: chiedersi che cosa migliorare.

> **ATTENZIONE**
> Gli errori più comuni negli studi medici: referti inviati per email non protetta o alla persona sbagliata; dati sanitari nelle chat del telefono personale; computer senza cifratura né backup verificato; nessuna informativa consegnata o nessuna prova di averla data; collaboratori senza istruzioni scritte; fornitori informatici con accesso ai dati e nessuna nomina; nessuna procedura per un incidente.

0.6 Dove Privacy Studio aiuta, e dove no

Adempimento	Privacy Studio	Resta al titolare
Mappa dei trattamenti e registro	Registro versionato, esportabile alla data (§ 6.4)	Decidere finalità e basi; completare sistemi, misure, fornitori, trasferimenti
Informativa	Schema, pubblicazione immutabile, registro delle consegne, verifica dell'integrità (§ 6.3)	Contenuto giuridico; stampa e consegna; rappresentanti legali
Diritti degli interessati	Registrazione, scadenze, proroga, decisione, chiusura con prova (§ 6.5)	Valutare e preparare il riscontro; identificazione del richiedente
Violazioni	Orologio delle 72 ore, valutazione, registro, protocollo di notifica (§ 6.6)	Decidere se è violazione e se notificare; fare la notifica
Conservazione	Regole, elementi scaduti, eliminazione guidata e documentata (§ 6.7)	Stabilire le durate; documentazione clinica fuori dal programma
Sicurezza dei dati	Accesso con blocco, audit a catena, backup cifrati verificati, ripristino (cap. 8)	Computer, rete, locali, telefoni, formazione
Persone autorizzate, fornitori, DPO/DPIA, formazione	Nulla (per ora)	Tutto

NOTA
Usare Privacy Studio **non rende da solo** lo studio conforme: aiuta a documentare e a rispettare le scadenze per alcuni adempimenti. Gli altri si fanno fuori dal programma, con il consulente.

0.7 Che cosa si rischia se non si è in regola

- **Poteri del Garante**: ispezioni, richieste di informazioni, ammonimenti, limitazioni o divieti di trattamento, ordini di adeguamento (art. 58); reclami degli interessati (art. 77).
- **Sanzioni amministrative pecuniarie**: fino a 10 milioni di euro (o il 2% del fatturato) per la violazione, tra gli altri, degli obblighi su registro, sicurezza, violazioni, nomine; fino a 20 milioni (o il 4%) per violazione dei principi, delle condizioni di liceità, dei diritti degli interessati (art. 83, par. 4 e 5). L'importo si gradua sul caso concreto (art. 83, par. 2).
- **Risarcimento** dei danni, materiali e immateriali, a chi li ha subiti (art. 82).
- **Sanzioni penali** del Codice per i casi più gravi, come il trattamento illecito di dati (art. 167 e seguenti), e le conseguenze sul piano **disciplinare** e della responsabilità professionale per la violazione del segreto.

DA ESAMINARE
Le sanzioni descritte sono i **massimi di legge**, non l'esito tipico; l'importo e l'applicabilità di ciascuna ipotesi dipendono dal caso e dalle norme vigenti. Informazione generale, non valutazione del rischio dello studio.

1. A che cosa serve Privacy Studio

1.1 Lo scopo

Un medico che esercita in proprio è **titolare del trattamento** dei dati dei pazienti (art. 4, n. 7 del Regolamento) e tratta dati relativi alla salute, che il Regolamento colloca fra le categorie particolari (art. 9). Questo comporta obblighi di documentazione, di trasparenza verso i pazienti, di risposta alle loro richieste, di gestione degli incidenti e di sicurezza. Privacy Studio raccoglie questi adempimenti in un solo strumento, tenuto sul computer dello studio, e conserva le prove di ciò che è stato fatto (il cosiddetto principio di responsabilizzazione, art. 5, par. 2 e art. 24).

> **RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 5 e art. 24**
> Il titolare deve essere in grado di **dimostrare** di aver rispettato i principi del trattamento (liceità, correttezza, trasparenza, limitazione della finalità, minimizzazione, esattezza, limitazione della conservazione, integrità e riservatezza).

1.2 Le sette funzioni

Funzione	Che cosa permette	Norma di riferimento
F01 Registro dei trattamenti	Elencare le attività di trattamento, le finalità, le basi giuridiche, le categorie di dati e di interessati; pubblicare versioni immutabili ed esportare il registro a una data.	Art. 30 GDPR
F02 Informative e consegne	Redigere e pubblicare l'informativa; registrare a chi e quando è stata consegnata, anche senza firma; ricostruire il modulo emesso.	Artt. 12, 13, 14 GDPR
F03 Richieste degli interessati	Registrare le richieste di accesso, rettifica, cancellazione ecc.; calcolare la scadenza; prorogare; decidere; chiudere con prova del riscontro.	Artt. 12, 15-22 GDPR; art. 2-terdecies Codice
F04 Violazioni dei dati	Registrare un incidente, avviare le 72 ore, valutare il rischio, documentare le azioni e la notifica al Garante.	Artt. 33 e 34 GDPR
F05 Conservazione	Fissare le durate di conservazione, vedere ciò che è scaduto, eliminare in modo guidato e documentato.	Art. 5, par. 1, lett. e) GDPR
F06 Backup e ripristino	Copie cifrate e verificate, copia fuori dal computer, ripristino su una macchina pulita, chiavi di recupero.	Art. 32 GDPR
F07 Rimozione di un interessato	Azzerare l'anagrafica e rendere anonime le prove di consegna, conservando la prova minima.	Art. 17 GDPR (con i limiti dell'art. 17, par. 3)

1.3 Che cosa Privacy Studio non fa

- **Non è una cartella clinica.** Non contiene diagnosi, terapie, referti né l'agenda delle visite. Per il registro dei trattamenti non servono le singole visite dei pazienti.
- **Non invia nulla** al Garante o ai pazienti: registra ciò che il medico ha fatto (per esempio il numero di protocollo della notifica) e ricorda le scadenze.

- **Non decide.** Non classifica da solo un incidente come violazione, non stabilisce se una richiesta va accolta, non fissa le durate di conservazione.
- **Non gestisce ancora** (previsto per una versione successiva): consensi e revoche per finalità diverse dalla cura, più utenti con ruoli diversi, contratti con i fornitori (responsabili del trattamento), ricerca in linguaggio naturale.

1.4 I principi di funzionamento

- **Dati ridotti al necessario** (art. 5, par. 1, lett. c): il programma non raccoglie ciò che non serve ai suoi scopi.
- **Il medico decide, il programma documenta**: nessuna scelta giuridica è preimpostata; nei moduli nessuna casella è già selezionata.
- **Ciò che è stato emesso non cambia**: una versione pubblicata del registro o dell'informativa non si modifica; si crea una nuova versione.
- **Tutto è tracciato**: ogni operazione importante finisce in un registro di audit a catena, che permette di accorgersi di manomissioni.
- **Le regole stanno nel database**: scadenze, immutabilità e completezza non dipendono da come è disegnata una schermata.

2. Il quadro normativo in sintesi

Questo capitolo riassume le norme che il programma presuppone. Per ognuna è indicato dove, nel programma, se ne vede l'effetto. Non è un elenco completo degli obblighi di uno studio medico: copre ciò che il programma tocca.

2.1 Le fonti

Fonte	Che cosa interessa lo studio
Regolamento (UE) 2016/679 (GDPR)	La disciplina generale: principi (art. 5), basi di liceità (art. 6), categorie particolari di dati (art. 9), trasparenza e diritti (artt. 12-22), registro (art. 30), sicurezza (art. 32), violazioni (artt. 33-34), valutazione d'impatto (art. 35), responsabile della protezione dei dati (artt. 37-39).
D.Lgs. 196/2003 (Codice in materia di protezione dei dati personali), come modificato dal D.Lgs. 101/2018	Le norme nazionali di adeguamento. Interessano in particolare l'art. 2-terdecies (diritti delle persone decedute), l'art. 2-quaterdecies (persone autorizzate al trattamento) e la Parte II, Titolo V, artt. 75 e seguenti (trattamento di dati in ambito sanitario).
Provvedimenti e linee guida del Garante e dell'EDPB	Chiarimenti operativi: ad esempio sul trattamento dei dati sanitari in ambito sanitario (Garante, provvedimento del 7 marzo 2019) e sulla notifica delle violazioni (linee guida dell'EDPB sulla notifica di violazioni dei dati personali).
Regolamento (CEE, Euratom) n. 1182/71	Le regole generali sul calcolo dei termini (giorni, mesi, festività). Il programma le applica per la scadenza delle risposte agli interessati. **Come vanno applicate qui è un punto da esaminare** (§ 6.5).
Codice civile e normativa fiscale	Conservazione di scritture e documenti contabili (es. art. 2220 del codice civile). Rilevante per fatture e documenti amministrativi, non per i dati clinici.

2.2 Perché non serve il consenso per curare, e quando serve

Il trattamento di dati sulla salute per finalità di cura, da parte di un professionista sanitario tenuto al segreto professionale, non richiede il consenso dell'interessato: si basa sull'art. 9, par. 2, lett. h) e par. 3 del Regolamento, insieme a una base dell'art. 6 (di norma l'esecuzione di un contratto o di misure precontrattuali, art. 6, par. 1, lett. b). Il Garante lo ha chiarito nel provvedimento del 7 marzo 2019. Per questo il programma registra la **consegna dell'informativa** e non un "consenso" del paziente.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 9, par. 2, lett. h) e par. 3
Il divieto di trattare dati sulla salute (art. 9, par. 1) non si applica se il trattamento è necessario per finalità di medicina preventiva, diagnosi, assistenza o terapia, sulla base del diritto dell'Unione o degli Stati membri o di un contratto con un professionista sanitario, quando i dati sono trattati da o sotto la responsabilità di un professionista soggetto al segreto professionale.

DA ESAMINARE
Il consenso resta necessario per finalità **diverse dalla cura** (per esempio comunicazioni promozionali, alcune forme di ricerca, adesione a servizi come il fascicolo sanitario elettronico, secondo la disciplina specifica). La gestione di consensi e revoche non è ancora nel programma. Quali trattamenti dello studio richiedano un consenso va verificato con il consulente.

2.3 Gli obblighi che il programma non copre da solo

- **Persone autorizzate** (art. 29 GDPR; art. 2-quaterdecies Codice): chi lavora nello studio sotto l'autorità del titolare (segretaria, collaboratori) deve essere istruito e designato. Il programma ha un solo utente (il medico); le istruzioni alle persone autorizzate vanno predisposte a parte.
- **Responsabili del trattamento** (art. 28 GDPR): fornitori che trattano dati per conto dello studio (assistenza informatica, servizi in cloud, commercialista per i dati che gli sono affidati) richiedono un contratto o atto di nomina. Non sono ancora gestiti dal programma.
- **Valutazione d'impatto** (art. 35) e **responsabile della protezione dei dati** (artt. 37 ss.): vedi il riquadro sotto.
- **Misure di sicurezza dell'ambiente** (art. 32): computer aggiornato, disco cifrato, antivirus, accessi, locali. Il programma ne tratta una parte (cap. 3 e 8).

DA ESAMINARE

DPO e valutazione d'impatto. Il considerando 91 del Regolamento afferma che il trattamento dei dati dei pazienti da parte di un singolo professionista sanitario non dovrebbe essere considerato "su larga scala", e il Garante ha precisato nelle proprie FAQ che il singolo professionista sanitario non è tenuto, di regola, a designare un DPO. Sulla base di ciò, per un medico che esercita da solo né il DPO né la valutazione d'impatto sono di norma obbligatori. La conclusione dipende però dalle dimensioni e dall'organizzazione reali dello studio (più medici, telemedicina, trattamenti innovativi): **da confermare con il consulente**.

3. Prima di installare

3.1 Requisiti

Elemento	Requisito	Note
Sistema operativo	Windows 10 o 11, 64 bit, con gli aggiornamenti installati	Un computer dedicato allo studio, non usato per altro.
Memoria e spazio	8 GB di memoria; almeno 5 GB liberi per il programma e il database	I dati del programma sono piccoli (anagrafiche, registri, prove di consegna); lo spazio per i backup va previsto a parte.
Database	PostgreSQL 17 (provato con la 17)	Installato sullo stesso computer, in ascolto solo su quel computer (§ 4.2).
Ambiente di esecuzione	Incluso nel programma	Il programma di installazione porta con sé .NET: non va installato a parte.
Supporto per la copia esterna	Disco esterno o altra macchina	**Indispensabile**: un backup sullo stesso disco non protegge da guasto, furto o incendio.
Supporto per le chiavi di recupero	Chiavetta o altro, custodito fuori dal PC	Vedi § 5.3.

3.2 Sicurezza del computer

Il programma protegge i propri dati (accesso con password, registro di audit, backup cifrati), ma non può compensare un computer non sicuro. L'art. 32 del Regolamento chiede misure tecniche e organizzative adeguate al rischio; per un computer che contiene dati sulla salute, almeno:

- **Cifratura del disco** (BitLocker o equivalente): se il computer viene rubato, i dati non sono leggibili.
- **Aggiornamenti** automatici di Windows e dei programmi; antivirus attivo.
- **Account Windows personale** con password; nessun account condiviso; blocco schermo automatico.
- **Nessuna esposizione in rete** del database (§ 4.2) e firewall attivo.
- **Backup** regolari su un supporto separato (cap. 5 e 6.8).
- Locali e dispositivi dello studio: chi può vedere lo schermo, dove sono i supporti dei backup.

> **RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 32, par. 1**
> Il titolare e il responsabile mettono in atto misure adeguate che comprendono, se del caso: la pseudonimizzazione e la cifratura dei dati personali; la capacità di assicurare riservatezza, integrità, disponibilità e resilienza dei sistemi; la capacità di ripristinare tempestivamente la disponibilità dei dati in caso di incidente; una procedura per provare e valutare regolarmente l'efficacia delle misure.

3.3 Che cosa preparare prima di iniziare

Che cosa	Perché serve	Chi lo decide o lo fornisce
Denominazione, titolare, indirizzo, contatto per le richieste privacy (email o PEC), telefono	Compaiono nelle informative.	Il medico
Eventuale DPO e relativo contatto	Va indicato nell'informativa se nominato.	Il medico, con il consulente
Elenco di chi lavora nello studio e dei fornitori che vedono dati (informatico, commercialista, laboratori, software)	Per le designazioni e le nomine; per i destinatari da indicare nell'informativa.	Il medico
Durate di conservazione per i diversi tipi di documentazione	Il programma non ne propone: vanno inserite dal titolare (§ 6.7).	Il medico, con il consulente
Testo dell'informativa	Il programma offre solo uno schema da completare (§ 6.3).	Il medico, con il consulente
Una persona di fiducia per l'installazione e l'assistenza	L'installazione tocca database e Windows.	Il medico

DA ESAMINARE

Assistenza informatica. Chi installa e mantiene il programma, se può accedere ai dati (anche solo in teoria), svolge un trattamento per conto dello studio: serve un atto di nomina a responsabile del trattamento (art. 28) o, se è una persona che lavora sotto l'autorità del titolare, una designazione (art. 29 e art. 2-quaterdecies). Quale delle due ricorra e come formalizzarla va deciso con il consulente.

4. Installazione

4.0 Installazione guidata (consigliata)

Il programma di installazione **PrivacyStudio-Setup-0.9.0.exe** fa in un solo passaggio ciò che i punti 4.1-4.5 descrivono a mano. Va eseguito **dall'utente Windows che userà il programma** (con i permessi di amministratore, che Windows chiede), perché i file di connessione e le chiavi sono personali di quell'utente.

1. Avviare il programma di installazione e confermare la richiesta di Windows. Scegliere la cartella del programma (di norma quella proposta).
2. **Password del database**: scegliere la password dell'amministratore (`postgres`), di almeno 10 caratteri. Annotarla in un luogo sicuro: serve per il ripristino dei backup e per la manutenzione. Se PostgreSQL 17 è già presente, il programma chiede la password esistente (non la salva).
3. **Backup**: indicare la cartella dei backup sul computer e la **copia esterna** (disco esterno o altra macchina). Il programma avvisa se la copia esterna manca o è sullo stesso disco di Windows.
4. Attendere: l'installazione di PostgreSQL richiede qualche minuto. Il programma installa PostgreSQL 17 (se manca) tenendolo in ascolto solo su questo computer, crea il database e i due ruoli con **password casuali generate da lui**, applica gli script dello schema, scrive i file di configurazione e crea i collegamenti.
5. Al termine avviare Privacy Studio: compare la **Prima configurazione** (§ 5.1).

- Le password dei due ruoli del database non vanno mai digitate dall'utente: la password del ruolo operativo è nel file `connection.txt` dell'utente; quella del ruolo di installazione è in un file riservato agli amministratori, nella cartella dei dati comuni di Windows.
- Se il database dello studio esiste già (aggiornamento del programma), l'installazione **non tocca i dati**. L'aggiornamento dello schema non è ancora automatico (punto 15 del cap. 9).
- La **disinstallazione** rimuove il programma ma **non** il database, i backup e le chiavi, che contengono dati dello studio.
- Per l'assistenza tecnica: l'installazione può essere non interattiva con i parametri `/VERYSILENT /PGPASSWORD=… /EXTERNALDIR=…`; con `/DRYRUN=1` mostra cosa farebbe senza modificare nulla.

ATTENZIONE
Il programma di installazione è una **bozza non ancora provata su un computer Windows pulito**. È stato compilato e verificato soltanto in "prova a secco" (sequenza dei passaggi, copia dei file, messaggi), ma l'installazione reale di PostgreSQL e la creazione del database con le password generate **non sono state eseguite**. Fino a quella prova, usare la procedura manuale qui sotto solo con l'aiuto dell'assistenza e senza dati reali. Il programma non è **firmato digitalmente**: Windows mostrerà l'avviso "editore sconosciuto".

Installazione manuale (riferimento tecnico)

I punti seguenti descrivono i passaggi che il programma di installazione automatizza. Servono per capire cosa succede, per l'assistenza e come alternativa.

4.1 Installare i componenti (manuale)

1. Installare **PostgreSQL 17** (programma di installazione di EDB). Durante l'installazione si sceglie la password dell'utente amministratore del database (`postgres`): annotarla in un luogo sicuro. Lasciare la porta predefinita (5432).

2. Il programma pubblicato in modalità autonoma (`--self-contained true`) include .NET: non serve installarlo a parte.
3. Copiare la cartella del programma (`Privacy.App` e le sue librerie) in una cartella dello studio, ad esempio `C:\Programmi\PrivacyStudio`.

> **DA ESAMINARE**
> La cartella del programma si ottiene oggi compilando il codice (`dotnet publish src\Privacy.App -c Release -r win-x64 --self-contained true`). Questo passaggio e l'avvio della versione Release su un computer pulito non sono ancora stati provati. Un installatore firmato è un obiettivo da realizzare prima del rilascio.

4.2 Tenere il database chiuso verso la rete

Il database deve accettare connessioni **solo dal computer stesso**. Nell'installazione standard di PostgreSQL è già così, ma va controllato:

- nel file `postgresql.conf` la riga `listen_addresses` deve valere `'localhost'`;
- nel file `pg_hba.conf` le connessioni devono essere ammesse solo da `127.0.0.1` e `::1` con metodo `scram-sha-256`;
- il firewall di Windows non deve avere una regola che apra la porta 5432 verso la rete.

4.3 Creare il database e i due ruoli

Lo schema usa due ruoli distinti: `privacy_migrator`, proprietario dello schema, usato solo per installare e aggiornare; `privacy_app`, usato dal programma, che non può modificare la struttura né alterare il registro di audit e le versioni pubblicate. Dalla cartella `db` del programma, in un terminale con gli strumenti di PostgreSQL (`psql`) disponibili:

```
createdb -U postgres privacy
psql -U postgres -d privacy -v ON_ERROR_STOP=1 -f 000_bootstrap_roles.sql
psql -U postgres -c "ALTER ROLE privacy_migrator PASSWORD ''"
psql -U postgres -c "ALTER ROLE privacy_app PASSWORD ''"
psql -U privacy_migrator -d privacy -v ON_ERROR_STOP=1 -f 001_schema_v1.sql
psql -U privacy_migrator -d privacy -v ON_ERROR_STOP=1 -f 002_catalogs.sql
psql -U privacy_migrator -d privacy -v ON_ERROR_STOP=1 -f 003_rules_and_grants.sql
psql -U privacy_migrator -d privacy -v ON_ERROR_STOP=1 -f 004_disposal_ledger.sql
```

Le due password dei ruoli sono diverse dalla password del medico nel programma e vanno scelte lunghe e casuali; vanno conservate insieme alle altre credenziali dell'installazione. Se uno script dà errore, **fermarsi** e non proseguire: l'opzione `ON_ERROR_STOP` serve a questo.

> **DA ESAMINARE**
> Non è ancora definita la procedura di **aggiornamento** dello schema del database quando uscirà una nuova versione del programma (nuovi script numerati dopo il 004, con una copia di sicurezza prima di applicarli). Va scritta e provata prima del rilascio.

4.4 Dire al programma come raggiungere il database

Il programma legge i parametri di connessione da un file di testo personale dell'utente Windows, `%LOCALAPPDATA%\PrivacyStudio\connection.txt`, con una sola riga:

```
Host=127.0.0.1;Port=5432;Database=privacy;Username=privacy_app;Password=
```

ATTENZIONE
Questo file contiene la password del database. Deve stare nella cartella dell'utente (non in una cartella condivisa), e non va copiato né inviato. In alternativa si può usare la variabile d'ambiente `PRIVACY_CONN`. La protezione di questa credenziale rientra nella decisione sulla gestione delle chiavi (§ 9, punto 1).

4.5 Cartelle dei backup e delle eliminazioni

Il file `%LOCALAPPDATA%\PrivacyStudio\config.json` indica dove salvare backup e registro esterno delle eliminazioni, e dove sono gli strumenti di PostgreSQL:

```
{ "ledgerPath": "D:\\Privacy\\disposals.jsonl",
  "backupDir": "D:\\Backup\\Privacy",
  "externalBackupDir": "E:\\CopiaEsterna",
  "pgBinDir": "C:\\Program Files\\PostgreSQL\\17\\bin" }
```

- **externalBackupDir** deve trovarsi su un supporto diverso dal computer (disco esterno, altra macchina).
- **ledgerPath**: elenco delle eliminazioni già fatte (solo identificativi, nessun dato personale); conviene su un disco diverso da quello del database.
- **pgBinDir**: cartella con `pg_dump` e `pg_restore`. Senza, il pulsante di backup resta disattivato e la scheda lo segnala.

4.6 Verifica finale dell'installazione

1. Avviare `Privacy.App.exe`: deve comparire la finestra **Prima configurazione** (§ 5.1). Se compare un errore di connessione, controllare `connection.txt` e che il servizio PostgreSQL sia attivo.
2. Completare la configurazione e accedere: deve aprirsi la finestra principale con le schede.
3. Aprire la scheda **Backup**: se `pgBinDir` è corretto, il pulsante **Esegui backup ora** è attivo.
4. Eseguire un primo backup e controllare che compaia come **Riuscito** con la data di verifica, e che i file siano nella cartella principale e nella copia esterna.

5. Primo avvio e configurazione

5.1 Prima configurazione dello studio

Al primo avvio, se il database non contiene ancora uno studio, si apre da sola la finestra **Prima configurazione**. Si inseriscono:

Campo	A che cosa serve
Denominazione dello studio	Compare nelle informative.
Titolare del trattamento	Nome e cognome del medico. È il soggetto che decide finalità e mezzi del trattamento (art. 4, n. 7).
Codice fiscale o partita IVA (facoltativo)	Identificativo del titolare nelle informative, se lo si vuole indicare.
Indirizzo dello studio	Compare nelle informative.
Contatto per le richieste privacy	Email o PEC a cui i pazienti scrivono per esercitare i diritti. Va mantenuto attivo e controllato.
Telefono (facoltativo), contatto del DPO (facoltativo)	Il contatto del DPO, se nominato, deve essere indicato nell'informativa (art. 13, par. 1, lett. b).
Nome utente, nome mostrato, password	Le credenziali del medico. La password deve avere almeno 12 caratteri, non essere troppo ripetitiva né contenere il nome utente. Non esiste un modo per recuperarla se dimenticata.

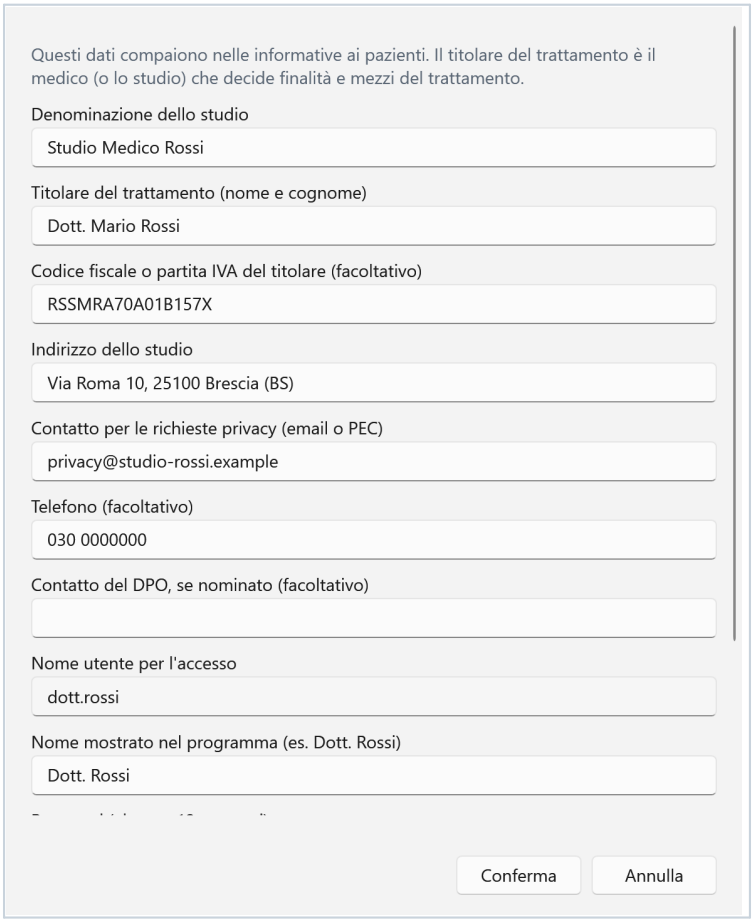


Figura 1 *- La finestra «Prima configurazione», compilata con dati inventati.*

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 13, par. 1, lett. a) e b)
L'informativa deve contenere l'identità e i dati di contatto del titolare e, se del caso, del responsabile della protezione dei dati.

ATTENZIONE
Lo studio si configura **una sola volta**. La modifica successiva dei dati dello studio (per esempio un cambio di indirizzo) non è ancora disponibile nell'interfaccia: va fatta con l'aiuto dell'assistenza. Le informative già pubblicate conservano i dati com'erano al momento della pubblicazione, per costruzione.

5.2 Accesso quotidiano

- Inserire nome utente e password. Il nome utente non distingue le maiuscole.
- Dopo **5 tentativi sbagliati** l'accesso è bloccato per **15 minuti**, anche se poi si inserisce la password giusta. Il blocco non si azzera riavviando il programma.
- I messaggi di errore sono volutamente uguali per "utente inesistente" e "password errata".
- Ogni accesso, riuscito o no, è registrato nel registro di audit (senza mai registrare le password).

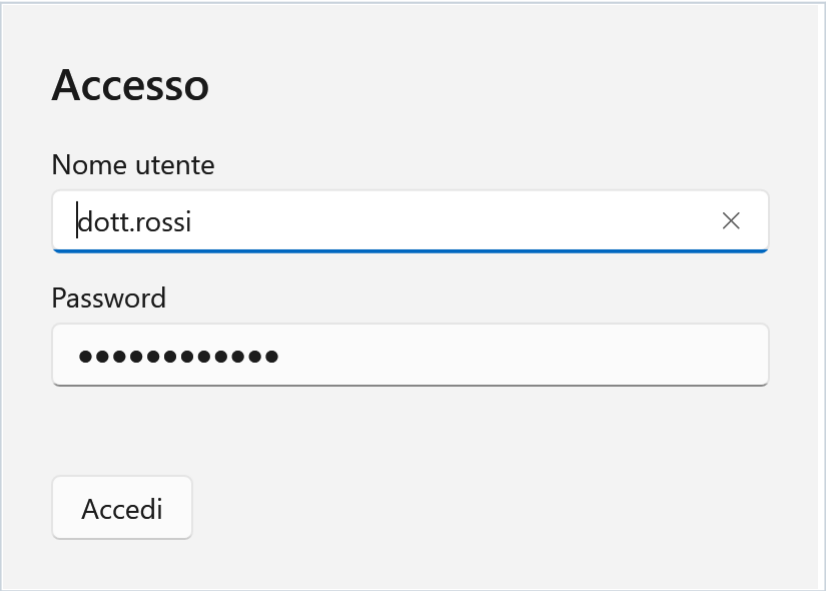


Figura 2 - La finestra di accesso.

DA ESAMINARE

Il **cambio della password** esiste come funzione del programma ma **non ha ancora una schermata**. Mancano anche la scadenza della sessione per inattività e il blocco dello schermo del programma: nel frattempo bloccare il computer (tasto Windows + L) ogni volta che ci si allontana.

5.3 Le chiavi di recupero: da fare subito

Il programma usa due chiavi segrete: una per cifrare i backup e una per firmare i moduli consegnati ai pazienti. Sono generate automaticamente e custodite da Windows, legate all'utente Windows con cui si lavora. **Se il computer o il profilo Windows si perdono, senza una copia delle chiavi i backup non si possono più aprire.** Per questo, subito dopo il primo accesso:

1. Aprire la scheda **Backup** e premere **Esporta chiavi di recupero…**.
2. Scegliere una **frase segreta** di almeno 14 caratteri, digitarla due volte e salvare il file (estensione `.pskr`).
3. Conservare il file **fuori dal computer** (chiavetta in cassaforte) e la frase segreta **in un luogo diverso**.
4. Prima di fidarsi, provare l'importazione su un altro computer (**Importa chiavi…**).

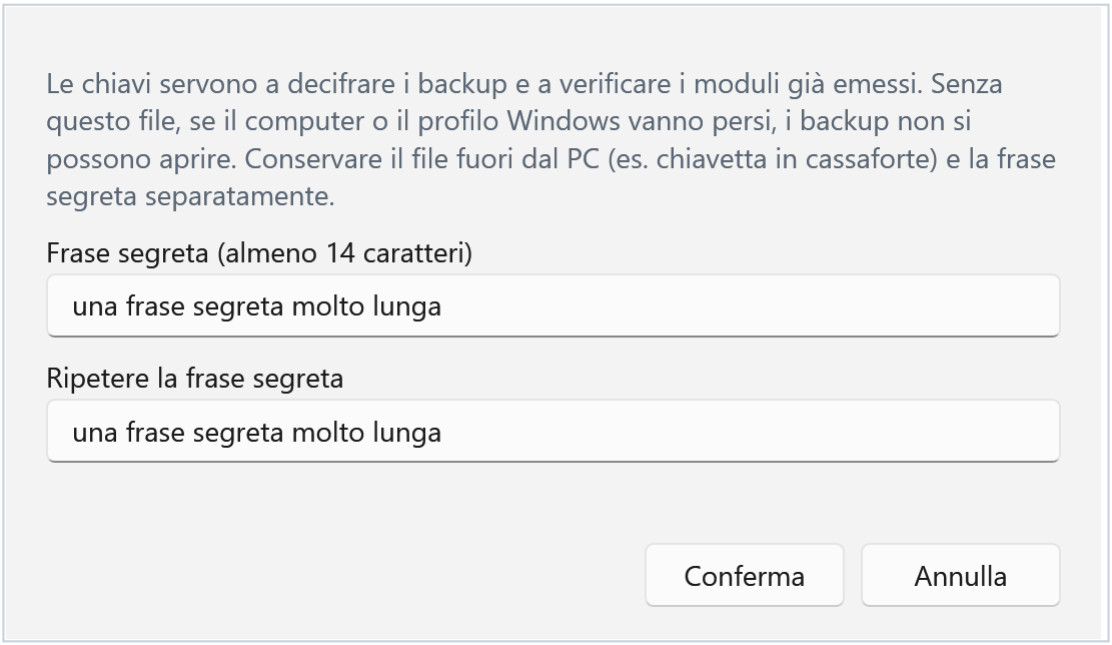


***Figura 3** - Esportazione delle chiavi di recupero (scheda Backup).*

ATTENZIONE

Importare chiavi su un computer che ne ha già **le sostituisce**: i backup e i moduli cifrati con le chiavi precedenti non saranno più apribili. Il programma chiede di digitare SOSTITUISCI per confermare.

DA ESAMINARE

Questa è una soluzione **provvisoria**. La decisione di fondo su come proteggere le chiavi e il database (cifratura del disco, cifratura dei singoli campi, gestione delle chiavi, procedura di recupero testata da una persona non tecnica) è ancora aperta ed è la prima condizione per l'uso con dati reali (§ 9, punto 1).

6. Uso del programma

6.1 La finestra principale

Dopo l'accesso si apre la finestra principale, divisa in schede. In alto, a destra, quattro pulsanti sempre disponibili: **Nuova richiesta…**, **Nuovo incidente…**, **Apri selezionata** (apre il dettaglio della riga scelta nella scheda Richieste o Incidenti) e **Aggiorna**.

Scheda	Che cosa mostra	Capitolo
Richieste in scadenza	Richieste degli interessati ancora aperte con scadenza entro 30 giorni o già scaduta, la più urgente per prima.	6.5
Incidenti aperti	Violazioni non chiuse, con la scadenza delle 72 ore in ora italiana e il tempo residuo.	6.6
Conservazione	Regole di conservazione, elementi scaduti, regole da rivedere.	6.7
Backup	Esecuzioni di backup, stato rispetto all'obiettivo di 24 ore, chiavi di recupero.	6.8
Registro	Le attività di trattamento e le loro revisioni.	6.4
Pazienti	Anagrafica degli interessati, consegna dell'informativa, storico.	6.2, 6.3
Informative	Le informative pubblicate.	6.3

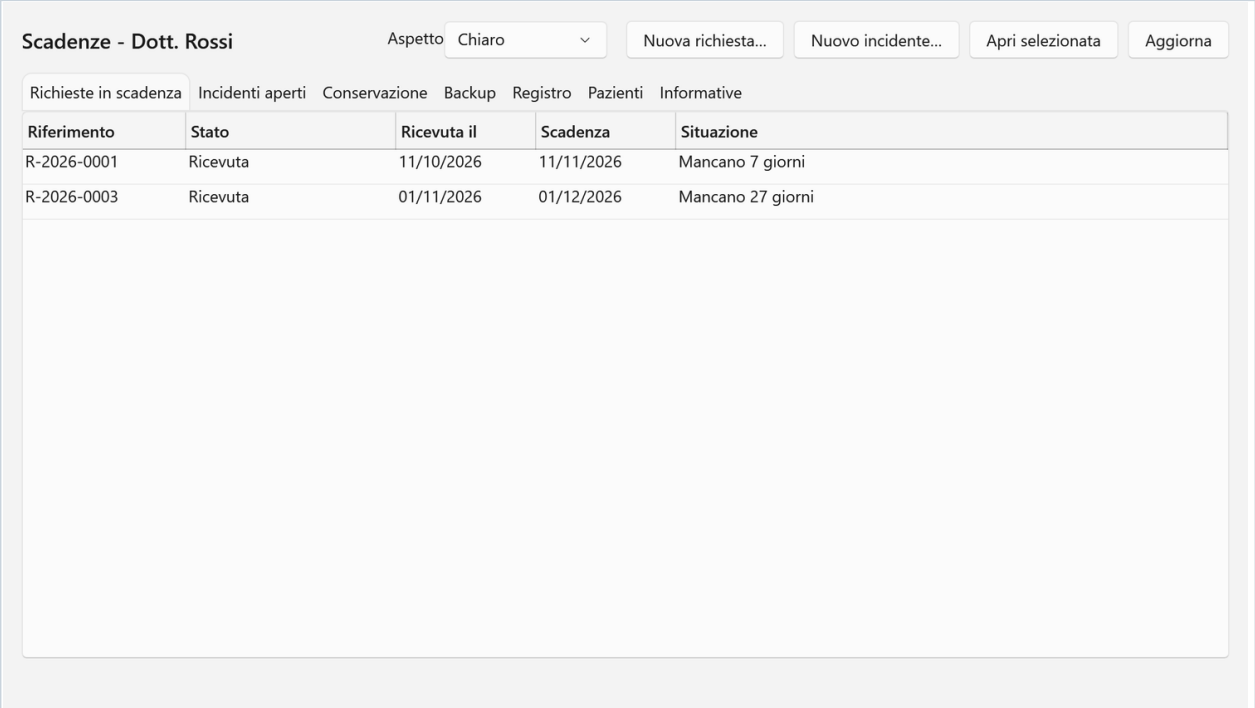


***Figura 4** - La finestra principale con la scheda «Richieste in scadenza». In alto i quattro pulsanti sempre disponibili.*

Regole comuni a tutte le schermate

- **Nessuna scelta preselezionata**: nelle liste a tendina bisogna scegliere esplicitamente; se si dimentica, il programma dice quale valore manca.

- **Scorciatoie da tastiera**: nei pulsanti e nelle etichette la lettera sottolineata, premuta insieme ad Alt, attiva il comando o porta al campo.
- **Messaggi di errore** in italiano; le regole del database (per esempio "chiusura impossibile: un diritto senza decisione") sono mostrate così come sono. Gli errori tecnici non mostrano dettagli, che potrebbero contenere dati.
- **Operazioni ripetibili**: se un salvataggio viene ripetuto per errore (doppio clic, ritentativo dopo un'interruzione), non crea duplicati.
- **Le date e le ore** sono sempre in ora italiana.

Aspetto: chiaro, scuro o come Windows

In alto, accanto ai pulsanti, il menu **Aspetto** permette di scegliere fra tre temi: **Come Windows** (è l'impostazione iniziale: il programma segue il tema chiaro o scuro e il colore d'accento scelti in Windows, e si adegua anche se il tema di Windows cambia mentre è aperto), **Chiaro** e **Scuro**. La scelta si applica subito a tutte le finestre ed è ricordata per l'utente Windows. I messaggi di errore e di esito cambiano colore per restare leggibili su fondo chiaro e scuro. Il tema non modifica alcun dato né stampa.

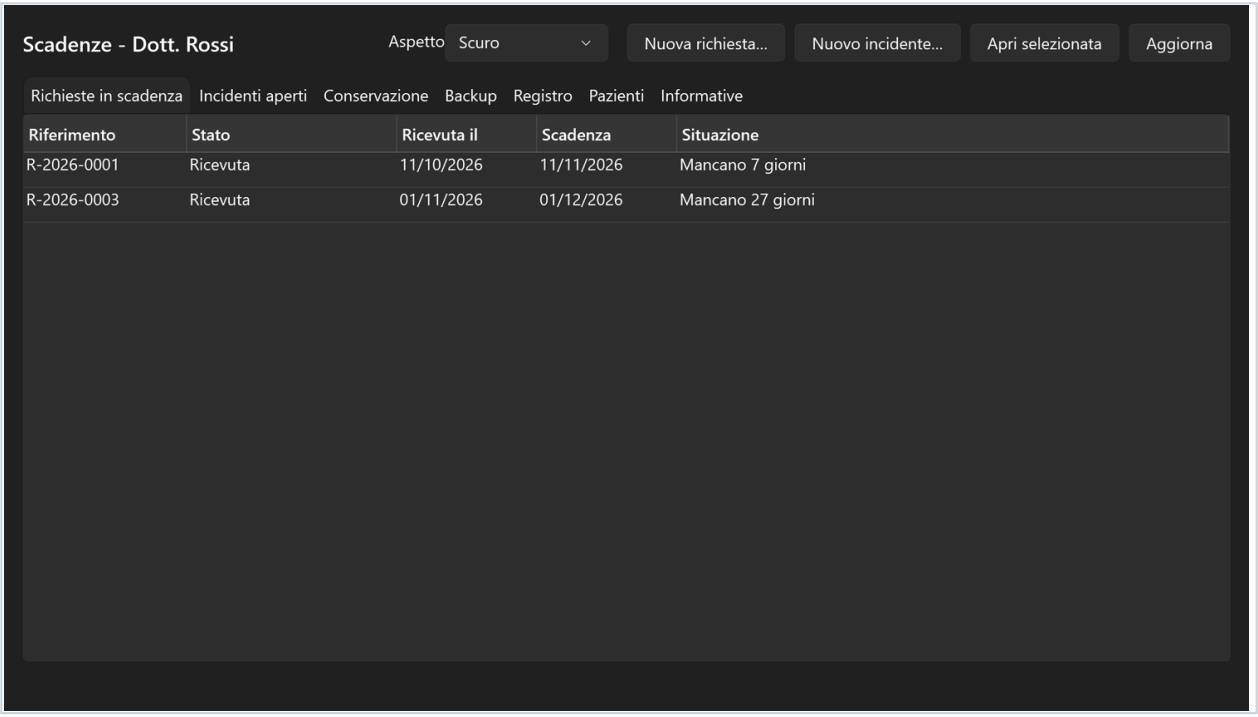


***Figura 5** - La stessa finestra principale con il tema scuro.*

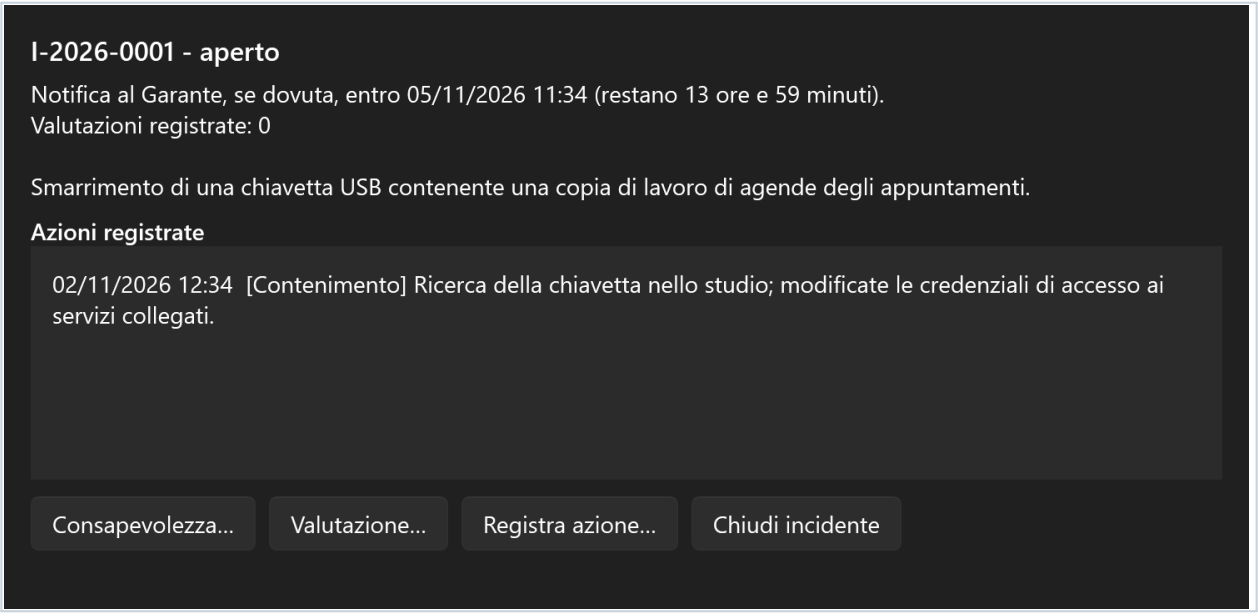


***Figura 6** - Il dettaglio di un incidente con il tema scuro.*

DA ESAMINARE
Il tema "Come Windows" è stato provato solo su Windows 11. Il comportamento su Windows 10, con schermi a scala diversa dal 100% o con la modalità a contrasto elevato, **non è stato verificato**. Il tema usa una funzione che Microsoft considera ancora sperimentale: va ricontrollata dopo gli aggiornamenti del programma di esecuzione.

6.2 Pazienti (anagrafica degli interessati)

La scheda **Pazienti** contiene l'anagrafica minima necessaria alle consegne delle informative: nome, cognome e, se si vuole, data di nascita, codice fiscale, email e telefono. A ogni persona il programma assegna un codice interno progressivo (`P-000001`, …). **Nessun dato clinico** viene inserito qui.

1. **Cercare**: scrivere nel campo **Cerca** parte del nome, del cognome o del codice; l'elenco si aggiorna.
2. **Nuovo interessato…**: compilare nome e cognome (obbligatori) e, se utile, gli altri campi.
3. **Rettifica…**: seleziona la riga e modifica l'anagrafica corrente.
4. **Consegne…** (o doppio clic): apre lo storico delle consegne della persona (§ 6.3).
5. **Rimuovi…**: vedi sotto.

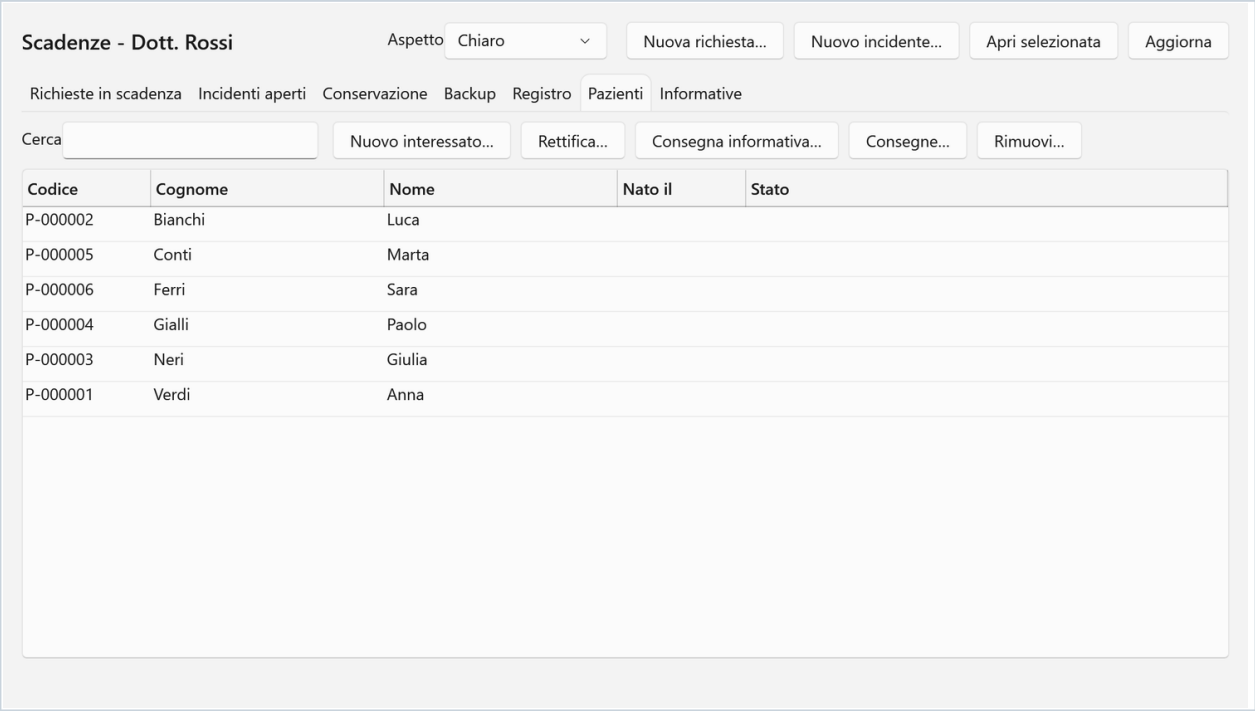


***Figura 7** - La scheda «Pazienti»: ricerca, nuovo interessato, rettifica, consegna dell'informativa, storico, rimozione.*

> **RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 16**
> L'interessato ha il diritto di ottenere la rettifica dei dati inesatti e, tenuto conto delle finalità, l'integrazione di quelli incompleti.

La **rettifica** cambia solo l'anagrafica di oggi: i moduli già consegnati restano com'erano stati emessi (il programma li ricostruisce dai dati salvati al momento della consegna).

La rimozione di un interessato

Rimuovi… è un'operazione **irreversibile**, da fare solo dopo che il titolare ha valutato la richiesta di cancellazione e gli obblighi di conservazione. Il programma chiede una motivazione e di digitare RIMUOVI. Dopo la rimozione:

- nome e cognome diventano "Interessato rimosso"; data di nascita, codice fiscale, email e telefono sono azzerati; il **codice interno resta**;
- le consegne passate restano come prova minima (esistenza, data, versione dell'informativa), ma con il nome azzerato e le note cancellate;
- i file collegati (per esempio la scansione di una ricevuta) vengono svuotati;
- l'operazione è registrata nel registro di audit e nel registro delle eliminazioni;
- la persona non è più modificabile, e il modulo della sua consegna non si può più ricostruire identico (l'impronta non coincide più): è voluto.

> **RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 17, par. 3, lett. b), c), e)**
> Il diritto alla cancellazione non si applica nella misura in cui il trattamento sia necessario, tra l'altro, per l'adempimento di un obbligo legale, per motivi di interesse pubblico nel settore della sanità pubblica (art. 9, par. 2, lett. h e i, e par. 3), o per l'accertamento, l'esercizio o la difesa di un diritto in sede giudiziaria.

DA ESAMINARE
La rimozione cancella **ciò che sta in Privacy Studio**. La documentazione clinica del paziente è altrove e segue obblighi di conservazione propri: prima di rimuovere un paziente dal programma, il titolare deve valutare (con il consulente) se una richiesta di cancellazione possa essere accolta in tutto o in parte, tenuto conto proprio dell'art. 17, par. 3, e di eventuali obblighi di conservazione della cartella clinica.

6.3 Informative e consegne

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, artt. 12, par. 1 e 13, par. 1
Il titolare adotta misure appropriate per fornire all'interessato, in forma concisa, trasparente, intelligibile e facilmente accessibile, con linguaggio semplice e chiaro, le informazioni previste dagli artt. 13 e 14. Se i dati sono raccolti presso l'interessato, l'informativa si dà **al momento** in cui i dati sono ottenuti.

Che cosa deve contenere l'informativa (art. 13)

- identità e contatti del titolare; contatti del DPO, se nominato;
- finalità del trattamento e base giuridica;
- destinatari o categorie di destinatari; eventuali trasferimenti verso paesi terzi;
- periodo di conservazione, o i criteri per determinarlo;
- i diritti dell'interessato (accesso, rettifica, cancellazione, limitazione, opposizione, portabilità) e il diritto di proporre reclamo al Garante;
- se il conferimento dei dati è obbligatorio o facoltativo e le conseguenze del mancato conferimento; l'esistenza di processi decisionali automatizzati, se ci sono.

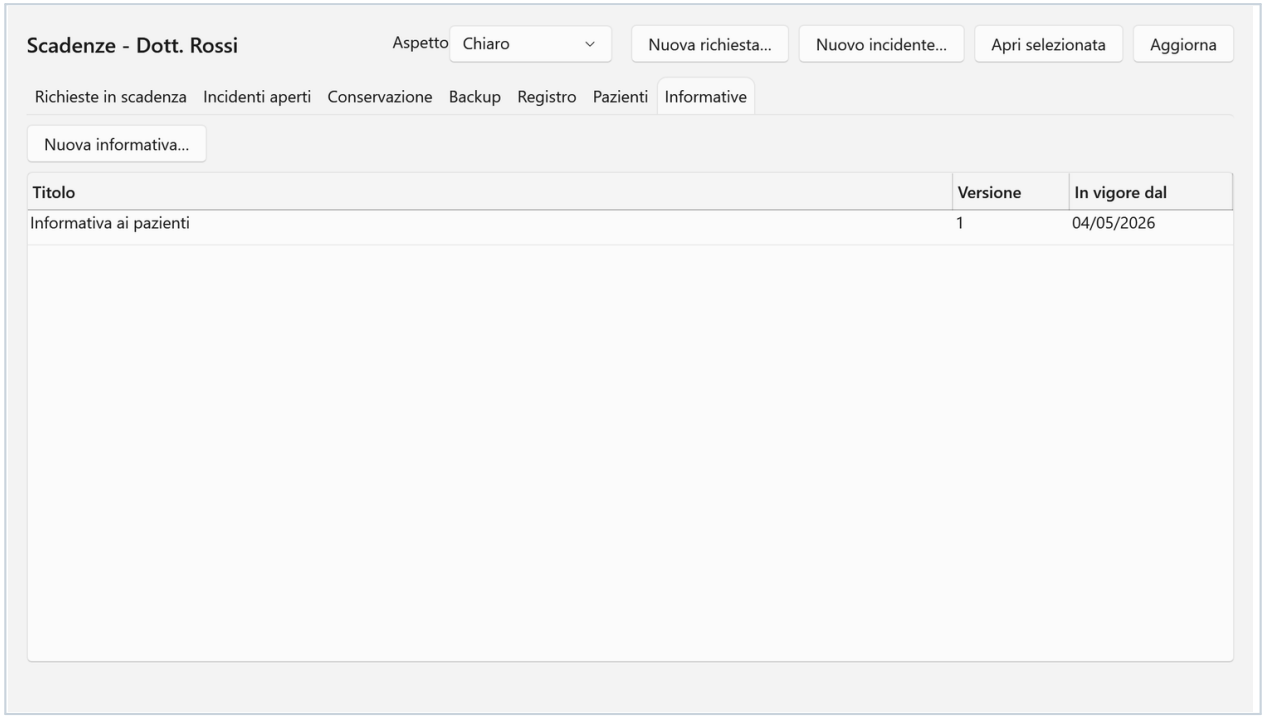


***Figura 8** - La scheda «Informative» con le informative pubblicate.*

Creare e pubblicare un'informativa

1. Prima serve nel **Registro** almeno un'attività di trattamento **pubblicata** (§ 6.4): l'informativa deve riferirsi a ciò che lo studio ha dichiarato di fare.

2. Scheda **Informative › Nuova informativa…**. Si compilano il titolo, il testo, la data di entrata in vigore e si selezionano le attività del registro a cui si riferisce (almeno una).
3. Il **testo di partenza** è solo uno schema: contiene variabili e promemoria `[Completare: …]` da sostituire con il contenuto che il titolare ha deciso.
4. Alla conferma il programma **sostituisce le variabili** con i dati correnti dello studio (denominazione, titolare, indirizzo, contatti, versione, data), calcola l'impronta del testo, approva e pubblica. Da quel momento il testo non cambia più.

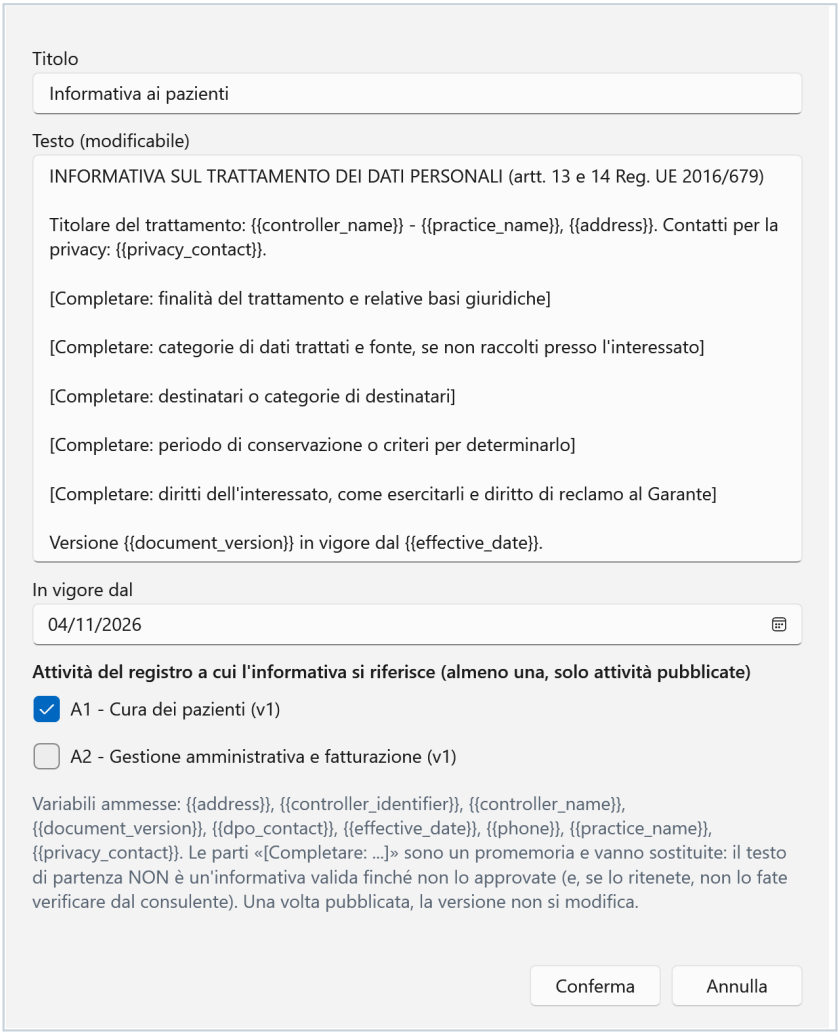


***Figura 9** - «Nuova informativa»: testo con variabili, data di entrata in vigore e attività del registro collegate.*

Le variabili ammesse

Si scrivono tra doppie graffe e sono un elenco chiuso: `{{practice_name}}` (denominazione), `{{controller_name}}` (titolare), `{{controller_identifier}}`, `{{address}}`, `{{privacy_contact}}`, `{{phone}}`, `{{dpo_contact}}`, `{{document_version}}` (numero di versione), `{{effective_date}}` (data di efficacia). Una variabile non ammessa, una variabile senza valore (per esempio il DPO se non è stato indicato) o un promemoria `[Completare…]` ancora presente **bloccano la pubblicazione**, e non resta alcuna bozza incompleta.

DA ESAMINARE

Contenuto dell'informativa. Il programma fornisce lo schema, non il testo giuridicamente adeguato: il contenuto (finalità, basi giuridiche, tempi di conservazione, destinatari, diritti) è del titolare e, se lo ritiene, del consulente. Il testo di partenza **non è un'informativa valida** finché non viene completato e approvato.
Per il medico di medicina generale e il pediatra di libera scelta il Codice contiene una norma specifica sulle informazioni da dare ai pazienti (art. 78): **se questo è il caso dello studio, va verificata con il consulente**.
Nessun aspetto grafico: il programma produce il **testo** del modulo. La stampa su carta intestata e il PDF non sono ancora disponibili.

Registrare la consegna

1. Scheda **Pazienti**, selezionare la persona, **Consegna informativa…**.
2. Scegliere l'**informativa** (versione pubblicata), la **modalità di consegna** (di persona, email, posta, altro) e l'**esito**.
3. Indicare la **data di consegna**. Per un tentativo fallito il campo va lasciato vuoto.
4. Se la riceve una persona diversa dal paziente (per esempio un genitore), indicarne **nome e qualità** nei campi del firmatario.
5. Alla conferma il programma mostra il **codice di consegna** (formato PS- seguito da 12 caratteri): è quello che compare sul modulo e serve a collegare una scansione alla consegna giusta.

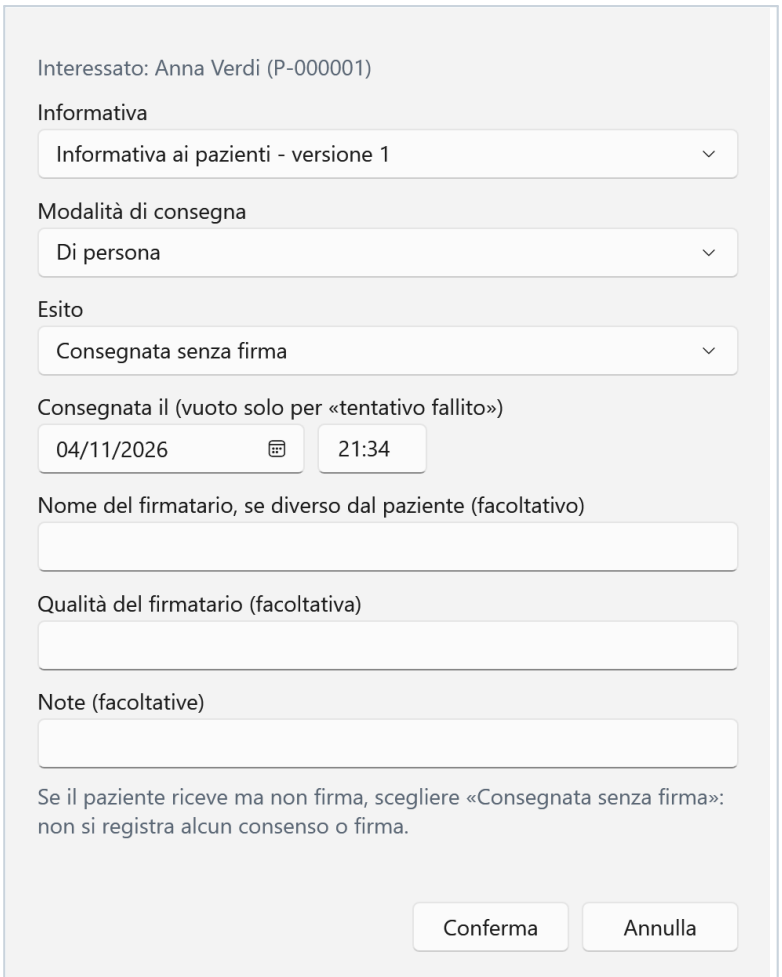


***Figura 10** - «Consegna informativa»: informativa, modalità, esito e data. Nessuna scelta è preselezionata (qui compilata a titolo di esempio).*

Esito	Significato
Consegnata senza firma	Il paziente ha ricevuto l'informativa ma non ha firmato. È un caso normale e lecito: non si registra alcuna firma o alcun consenso.
Ricevuta firmata	Il paziente ha firmato una ricevuta (che può essere acquisita come scansione).
Firma rifiutata (consegna avvenuta)	La consegna c'è stata, ma il paziente non ha voluto firmare.
Tentativo fallito	La consegna non è avvenuta (per esempio email respinta): senza data di consegna.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, artt. 5, par. 2, 12 e 13
La consegna dell'informativa è un obbligo del titolare e non richiede il consenso dell'interessato né una sua firma: ciò che il titolare deve poter dimostrare è di aver **fornito** l'informazione. Per questo il programma distingue la consegna dalla firma e non inventa sottoscrizioni.

Lo storico e la verifica dell'integrità

Da **Pazienti › Consegne…** si vedono le consegne di una persona. Selezionandone una e premendo **Mostra modulo** il programma **ricostruisce il testo** a partire dai dati salvati al momento della consegna e ne ricalcola l'impronta (un codice di controllo con chiave segreta). Se coincide con quella salvata, il modulo è identico a quello emesso, anche se nel frattempo l'indirizzo dello studio è cambiato. Il testo si può copiare negli appunti.

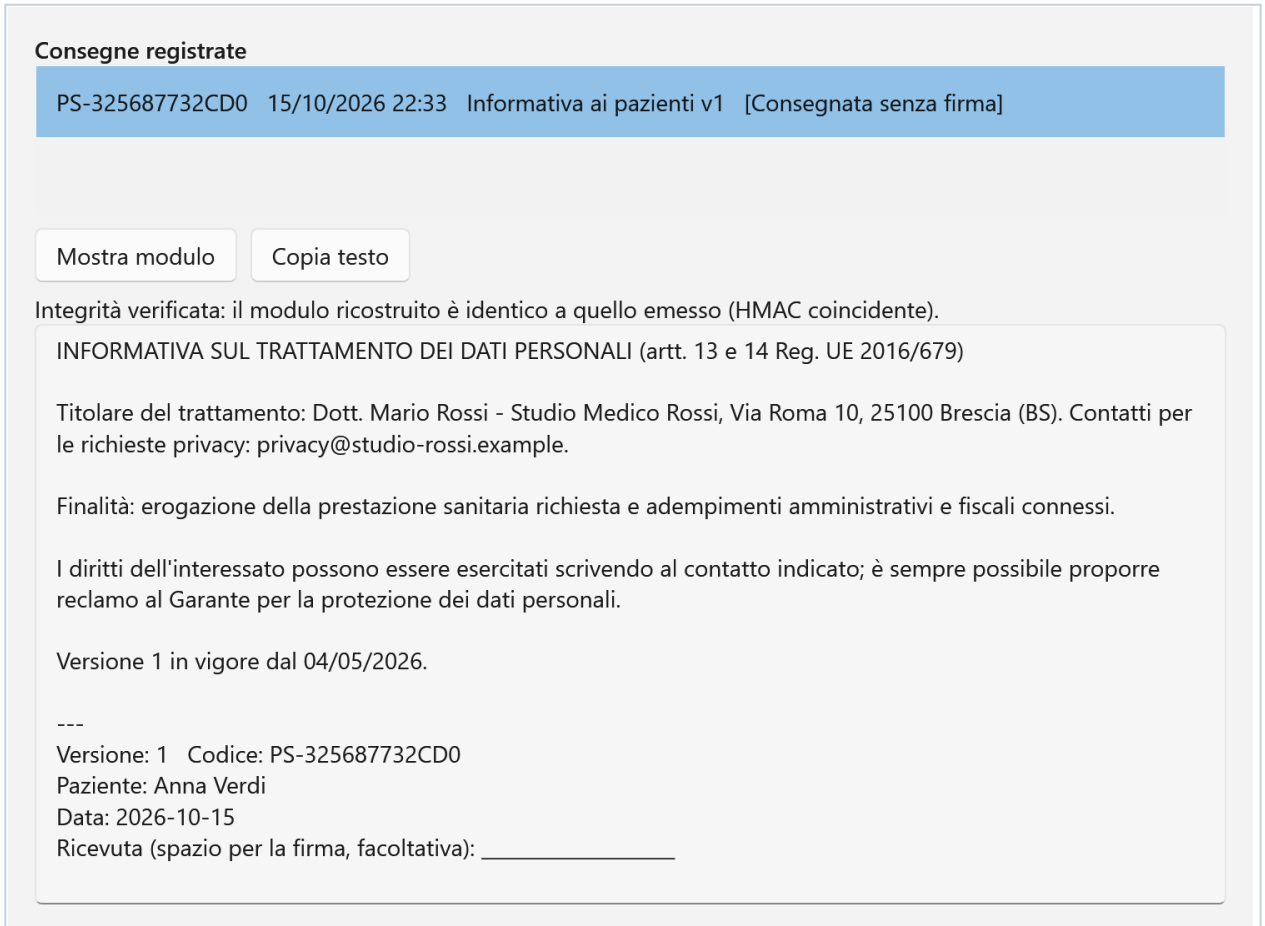


***Figura 11** - Storico delle consegne di un paziente, con il modulo ricostruito e la verifica dell'integrità.*

DA ESAMINARE

Rappresentanti legali. La struttura dati prevede la rappresentanza di minori o incapaci con verifica dei poteri e delle date di validità, ma la **schermata per gestirla non esiste ancora**: oggi chi riceve per un minore si indica a testo libero come firmatario. Come documentare i poteri di chi ritira per conto di un minore o di una persona sotto tutela va deciso con il consulente.

6.4 Registro dei trattamenti

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 30, par. 1 e 4

Ogni titolare tiene un registro delle attività di trattamento svolte sotto la propria responsabilità, in forma scritta (anche elettronica), con: nome e contatti del titolare; finalità; descrizione delle categorie di interessati e di dati; categorie di destinatari; trasferimenti verso paesi terzi; ove possibile, termini ultimi per la cancellazione; descrizione generale delle misure di sicurezza. Il registro è messo a disposizione del Garante su richiesta.

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 30, par. 5

L'esenzione per imprese e organizzazioni con meno di 250 dipendenti **non si applica** se il trattamento non è occasionale o include categorie particolari di dati (art. 9): per uno studio medico il registro è quindi dovuto.

Il registro è composto da **attività** (per esempio "Cura dei pazienti", "Gestione amministrativa e fatturazione"). Ogni attività ha **revisioni** numerate: una revisione pubblicata non si modifica; per cambiare qualcosa si crea una nuova revisione. Così il registro "alla data T" si può sempre ricostruire.

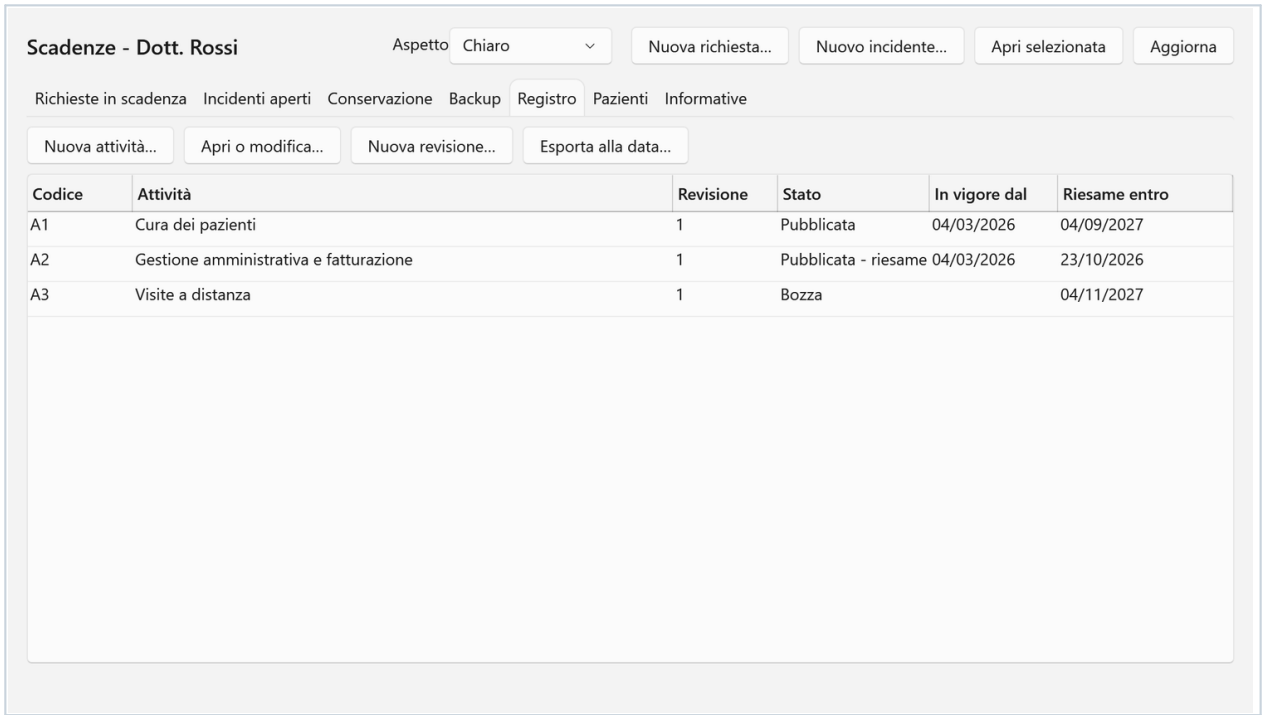


__Figura 12__ - La scheda «Registro»: l'attività A2 mostra «Pubblicata - riesame scaduto», A3 è in bozza.

Creare un'attività

1. Scheda **Registro › Nuova attività…**: codice (es. A1) e nome. L'attività nasce in bozza e si apre l'editor.
2. Nell'editor: **descrizione** dell'attività e **data di riesame** prevista (entro quando il titolare riguarderà la scheda).

3. **Categorie**: spuntare le categorie di dati (anagrafici, contatto, dati sulla salute, …), di interessati (pazienti, minori, collaboratori, fornitori, …) e di destinatari. Nessuna è preselezionata.
4. **Finalità**: **Aggiungi finalità…** con nome, descrizione, valutazione giuridica del titolare, valutazione sul consenso (necessario / non necessario) e la prima **base giuridica**: art. 6 e, se si trattano dati sulla salute, la condizione dell'art. 9; riferimento normativo (facoltativo) e a quale parte della finalità si applica. **Aggiungi presupposto…** aggiunge altre basi alla finalità selezionata; **Rimuovi finalità** la toglie (solo in bozza).
5. **Salva dati e categorie**, poi **Invia in verifica** e infine **Pubblica…** indicando la data di entrata in vigore.

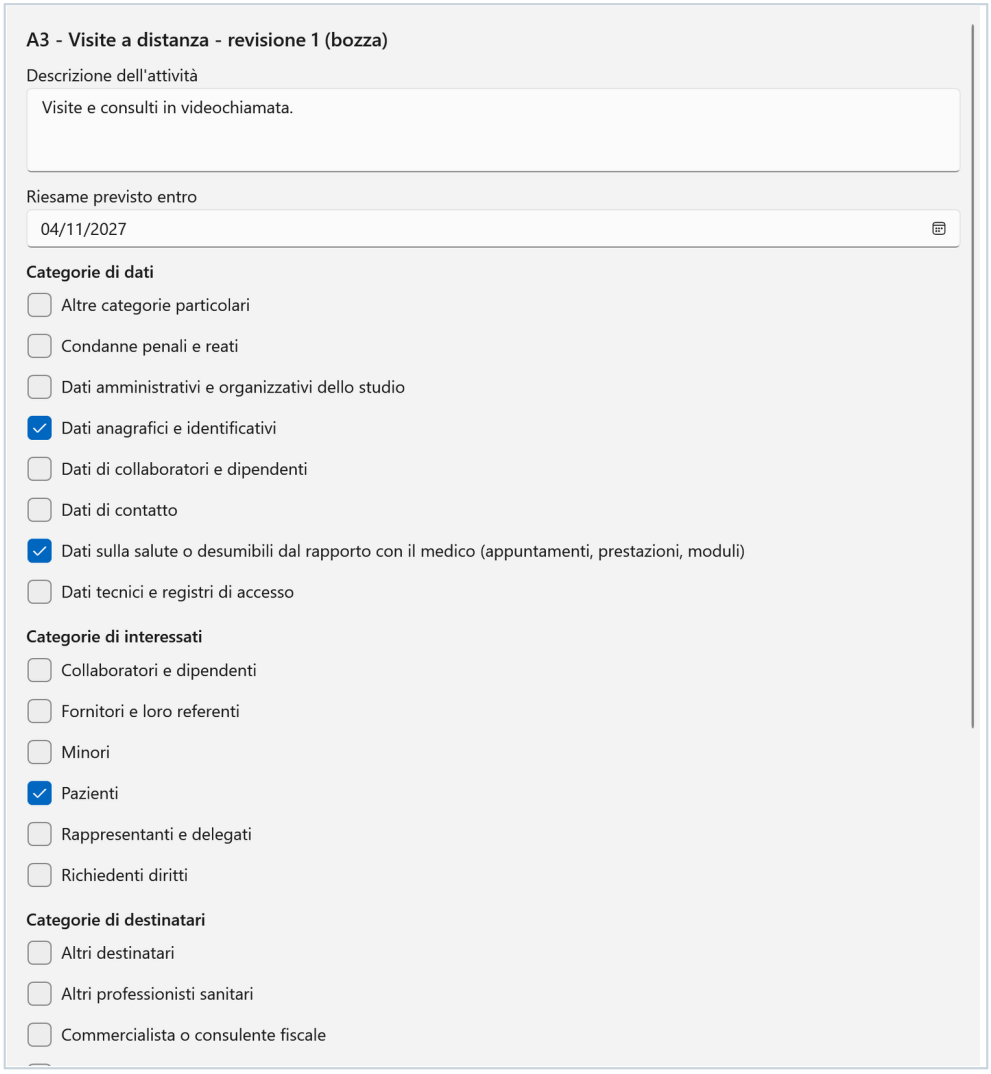


***Figura 13** - L'editor di una revisione in bozza: descrizione, riesame, categorie e finalità.*

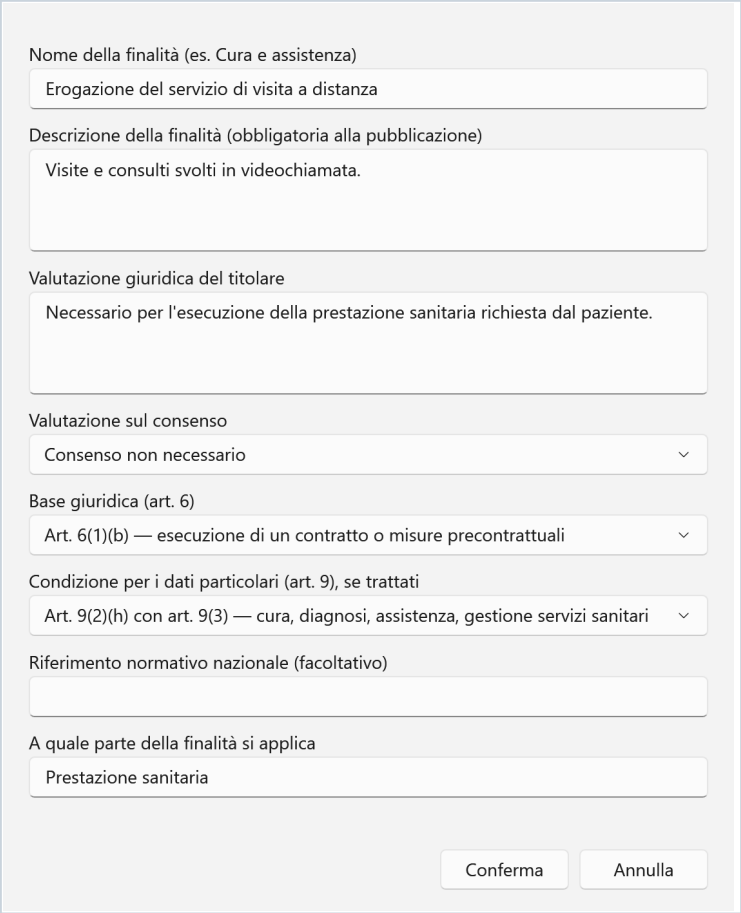


***Figura 14** - «Nuova finalità»: valutazione giuridica, base dell'art. 6 e condizione dell'art. 9 per i dati sulla salute.*

Che cosa controlla il programma alla pubblicazione

- descrizione dell'attività, data di riesame e approvazione presenti;
- almeno una finalità, e per ogni finalità: descrizione, valutazione giuridica, almeno un presupposto, consenso già valutato (non "da valutare");
- almeno una categoria di dati e una di interessati;
- nessuna categoria di dati "da valutare";
- se ci sono **dati sulla salute** (art. 9), almeno una finalità con la condizione dell'art. 9; se ci sono dati su condanne penali o reati (art. 10), un riferimento a una disposizione che lo consenta.

Se manca qualcosa la pubblicazione è **rifiutata** e il messaggio elenca tutto ciò che manca. Con la pubblicazione la revisione diventa immutabile e la precedente diventa "superata" nello stesso istante.

Nuova revisione ed esportazione

- **Nuova revisione…** (da una revisione pubblicata) copia finalità, basi e categorie; si modifica la copia, indicando il motivo, e la si pubblica quando è pronta. La revisione precedente resta in vigore fino ad allora.
- **Esporta alla data…** produce un testo leggibile del registro com'era a quella data (copiabile o salvabile come file), da mostrare al Garante se lo chiede. Modifiche successive non cambiano l'esportazione di una data passata.
- Lo stato "**Pubblicata - riesame scaduto**" segnala le attività la cui data di riesame è passata.

```
REGISTRO DELLE ATTIVITÀ DI TRATTAMENTO - Studio Medico Rossi
Situazione alla data 04/11/2026 (art. 30 Reg. UE 2016/679)

A1 - Cura dei pazienti (revisione 1, in vigore dal 04/03/2026; riesame entro 04/09/2027)
  Descrizione: Gestione del rapporto di cura con i pazienti.
  Finalità: Cura e assistenza - Gestione del rapporto di cura con i pazienti.
    Valutazione sul consenso: Consenso non necessario
    Base giuridica: Art. 6(1)(b) – esecuzione di un contratto o misure precontrattuali; condizione art.
9: Art. 9(2)(h) con art. 9(3) – cura, diagnosi, assistenza, gestione servizi sanitari (Cura e
assistenza)
  Categorie di dati: Dati di contatto, Dati sulla salute o desumibili dal rapporto con il medico
(appuntamenti, prestazioni, moduli), Dati anagrafici e identificativi
  Categorie di interessati: Pazienti
  Destinatari: Nessuno oltre al titolare e alle persone autorizzate

A2 - Gestione amministrativa e fatturazione (revisione 1, in vigore dal 04/03/2026; riesame entro
23/10/2026)
  Descrizione: Fatturazione e adempimenti contabili.
  Finalità: Adempimenti amministrativi e fiscali - Fatturazione e adempimenti contabili.
    Valutazione sul consenso: Consenso non necessario
    Base giuridica: Art. 6(1)(b) – esecuzione di un contratto o misure precontrattuali (Adempimenti
amministrativi e fiscali)
  Categorie di dati: Dati di contatto, Dati anagrafici e identificativi
  Categorie di interessati: Pazienti
  Destinatari: Nessuno oltre al titolare e alle persone autorizzate

Nota: l'esportazione non include ancora sistemi, misure di sicurezza e incarichi dei fornitori, né i
termini di conservazione per finalità.
```

Copia Salva come file...

Figura 15 *- Esportazione del registro alla data scelta: testo leggibile, copiabile e salvabile.*

DA ESAMINARE

Completezza rispetto all'art. 30. L'editor e l'esportazione non comprendono ancora i **sistemi** usati, le **misure di sicurezza** per attività, i **fornitori** (responsabili) e i **trasferimenti verso paesi terzi**; i termini di cancellazione sono nel modulo Conservazione ma non nell'esportazione. Finché mancano, queste parti vanno documentate a parte (la nota in fondo all'esportazione lo ricorda).
La **scelta delle basi giuridiche** e delle condizioni dell'art. 9 è del titolare: il programma le registra e controlla che ci siano, non che siano giuste.

6.5 Richieste degli interessati

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 12, par. 3 e 4

Il titolare agevola l'esercizio dei diritti e fornisce le informazioni sull'azione intrapresa **senza ingiustificato ritardo e, comunque, al più tardi entro un mese** dal ricevimento della richiesta. Il termine può essere **prorogato di due mesi**, se necessario, tenuto conto della complessità e del numero delle richieste; l'interessato è informato della proroga e dei motivi del ritardo entro un mese dal ricevimento. Se il titolare non ottempera, informa l'interessato senza ritardo, e al più tardi entro un mese, dei motivi e della possibilità di proporre reclamo al Garante.

Diritto	Articolo	In sintesi
Accesso	15	Sapere se i dati sono trattati, ottenerne copia e le informazioni collegate.
Rettifica	16	Correggere o integrare dati inesatti o incompleti.
Cancellazione	17	Cancellazione senza ingiustificato ritardo nei casi previsti, con le eccezioni del par. 3.
Limitazione	18	Contrassegnare i dati in attesa di verifiche o in altri casi previsti.
Portabilità	20	Ricevere i dati in formato strutturato, quando il trattamento si basa su consenso o contratto ed è automatizzato.
Opposizione	21	Opporsi a trattamenti basati su interesse pubblico o legittimo interesse.

La richiesta può arrivare da **qualunque canale** (di persona, email, PEC, posta, telefono) e anche da chi **non è un paziente** (un collaboratore, un fornitore, un erede): il programma non richiede che esista una scheda del paziente.

Registrare una richiesta

1. **Nuova richiesta…**: nome del richiedente, **qualità** (interessato, rappresentante o delegato, erede o avente interesse, altro), canale, data e ora di ricezione (di norma adesso), testo e **diritti richiesti** (almeno uno).
2. Alla conferma il programma assegna il riferimento (`R-2026-0001`, …) e **calcola la scadenza** (§ seguente), che compare nella scheda **Richieste in scadenza**.
3. **Apri selezionata** (o doppio clic) mostra il dettaglio: i diritti richiesti con il loro stato, la cronologia e le azioni.

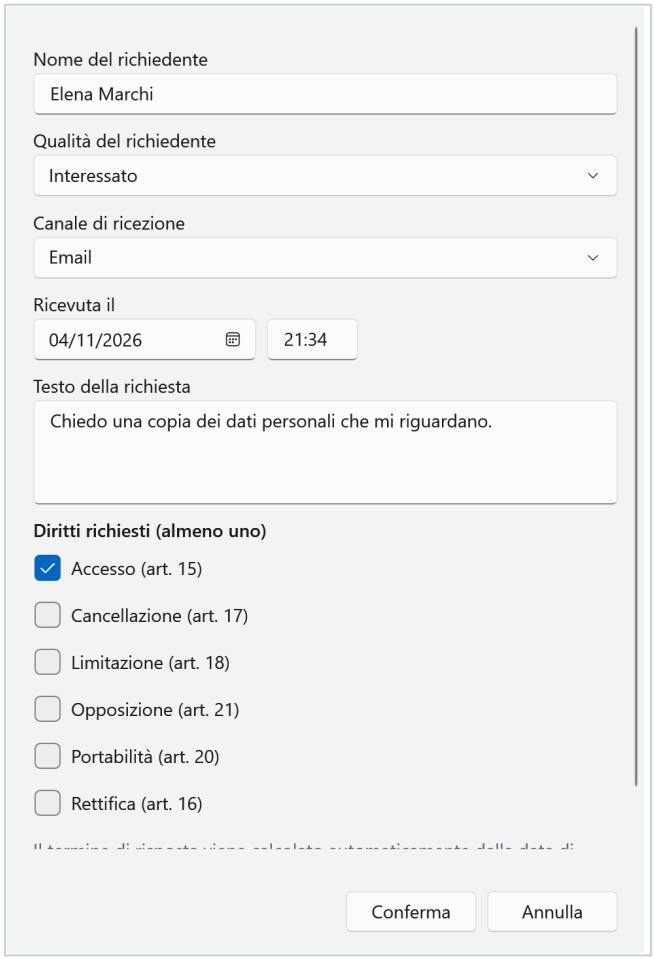


***Figura 16** - «Nuova richiesta»: richiedente, qualità, canale, data di ricezione, testo e diritti (almeno uno).*

Come si calcola la scadenza

Regola applicata (identificata nel programma come `it-1182-v1`), ispirata al Regolamento (CEE, Euratom) n. 1182/71: il giorno di ricezione non conta; la scadenza è il **giorno corrispondente del mese successivo**; se quel giorno non esiste (per esempio 31 gennaio) è l'ultimo giorno del mese; se cade di sabato, domenica o in una festività nazionale (compreso il lunedì di Pasqua) slitta al **primo giorno lavorativo successivo**. La data si intende nel fuso orario italiano. Alcuni esempi sono nell'Appendice B.

DA ESAMINARE

La regola di calcolo va confermata dal consulente. Non è pacifico come il Regolamento 1182/71 si applichi ai termini dell'art. 12 né se lo slittamento a giorno lavorativo spetti anche al termine di *risposta* (e non solo ai termini di *azione*). Finché non è confermata, il programma mostra la scadenza calcolata con questa regola: **per cautela, rispondere sempre prima**.

La proroga: il programma accetta una proroga fino a **tre mesi complessivi dalla ricezione** (un mese più due). Se invece i due mesi di proroga si sommassero alla scadenza già calcolata (per esempio 28 febbraio più due mesi) il limite cambierebbe. Anche questo è da confermare.

Il programma **non registra la verifica dell'identità** del richiedente (art. 12, par. 6: il titolare può chiedere informazioni supplementari in caso di dubbio ragionevole); va annotata nella cronologia o a parte. La struttura dati è prevista, la schermata no.

Costi e richieste manifestamente infondate o eccessive (art. 12, par. 5): le informazioni sono gratuite, salvo il caso di richieste manifestamente infondate o eccessive. La valutazione è del titolare.



***Figura 17** - Dettaglio di una richiesta: diritti con il loro stato, cronologia e azioni (Proroga, Decisione, Chiudi richiesta).*

Prorogare, decidere, chiudere

- **Proroga…**: nuova scadenza (in avanti, entro il limite), **motivazione** obbligatoria e, se già comunicata, la data di comunicazione all'interessato. La scadenza iniziale resta registrata: non si cancella.
- **Decisione…**: per ogni diritto si sceglie l'**esito** (accolta, accolta in parte, respinta, non applicabile). La **motivazione** è obbligatoria se non è accolta del tutto. Si indica la data di invio del riscontro quando è avvenuto; se è ancora da inviare si lascia vuota.
- **Chiudi richiesta**: possibile solo se **ogni** diritto richiesto ha una decisione **con riscontro inviato**. Altrimenti il programma rifiuta e dice quanti diritti mancano.

RIFERIMENTO NORMATIVO - D.Lgs. 196/2003, art. 2-terdecies

Persone decedute. I diritti riguardanti dati di persone decedute possono essere esercitati da chi ha un interesse proprio, o agisce a tutela dell'interessato come mandatario, o per ragioni familiari meritevoli di protezione. Nel programma si registra scegliendo come qualità **Erede o avente interesse**.

DA ESAMINARE

Accesso alla documentazione sanitaria. Per le strutture sanitarie la legge 8 marzo 2017, n. 24 (art. 4) prevede termini specifici (ricordati come sette giorni) per fornire al paziente la documentazione sanitaria. Se e come questa disposizione si applichi a uno studio professionale individuale, e quale termine prevalga sul termine ordinario dell'art. 12 GDPR, **va verificato con il consulente**.
Il testo della richiesta e il nome del richiedente sono dati personali conservati nel programma: la loro durata di conservazione va decisa (§ 6.7).

6.6 Violazioni dei dati (incidenti)

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 33, par. 1 e 5
In caso di violazione di dati personali il titolare notifica la violazione all'autorità di controllo **senza ingiustificato ritardo e, ove possibile, entro 72 ore** dal momento in cui ne è venuto a conoscenza, a meno che sia improbabile che la violazione presenti un rischio per i diritti e le libertà delle persone fisiche. Se la notifica non è fatta entro 72 ore, è corredata dei motivi del ritardo. Il titolare **documenta qualsiasi violazione**, comprese le circostanze, le conseguenze e i provvedimenti adottati (anche se non notificata).

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 34
Quando la violazione è suscettibile di presentare un **rischio elevato** per i diritti e le libertà delle persone, il titolare la comunica senza ingiustificato ritardo anche agli interessati, salvo le eccezioni del par. 3 (dati resi incomprensibili, misure successive che escludono il rischio, sforzo sproporzionato).

Una violazione non è solo un furto di dati: è anche la **perdita** o l'**indisponibilità** dei dati (per esempio un guasto o un attacco che impedisce di accedere alle cartelle) e l'accesso o la modifica non autorizzati. Il programma permette di registrare anche un incidente di sola indisponibilità come violazione.

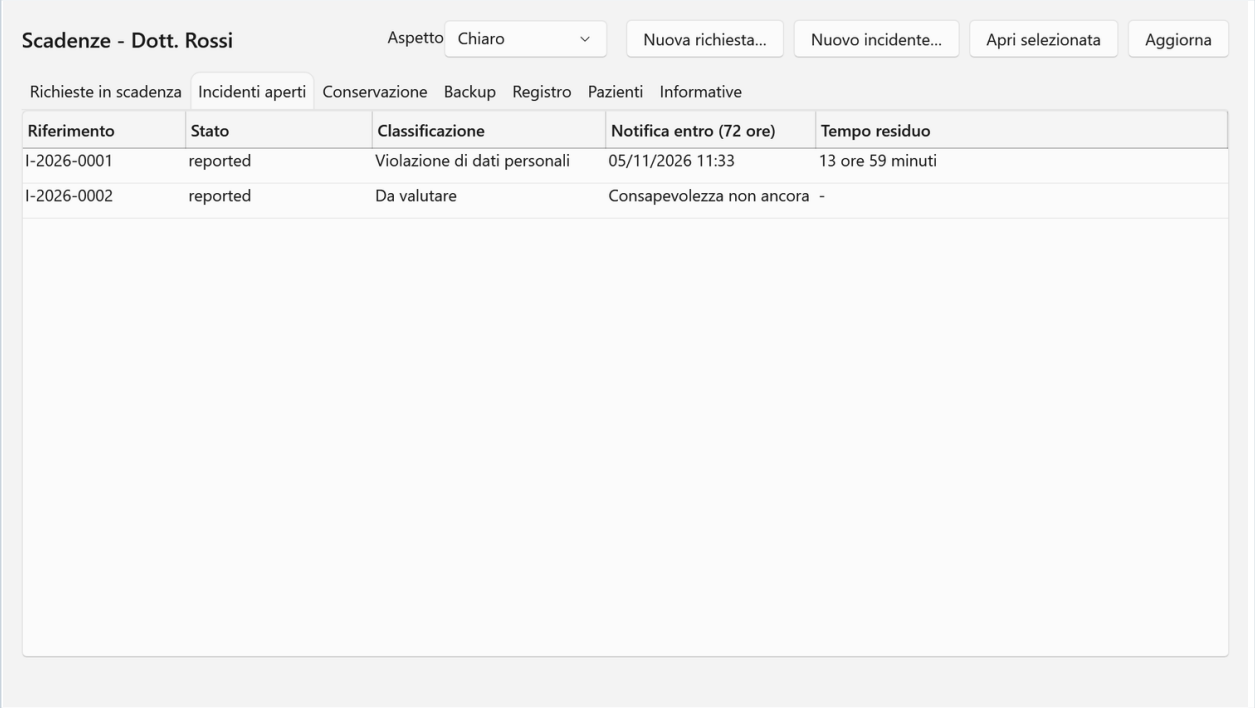


***Figura 18** - La scheda «Incidenti aperti»: scadenza delle 72 ore in ora italiana e tempo residuo.*

Che cosa fa il programma

1. **Nuovo incidente…**: quando è stato **rilevato**, quando il titolare ne è **venuto a conoscenza** (se già accertato; altrimenti il campo resta vuoto), descrizione e classificazione provvisoria (da valutare, incidente tecnico senza dati personali, violazione di dati personali).
2. Dal momento della consapevolezza partono le **72 ore**, calcolate su **istanti reali** (non in giorni lavorativi, e correttamente anche attraverso il cambio dell'ora). La scheda **Incidenti aperti** mostra la scadenza in ora italiana e il tempo residuo.
3. Nel dettaglio: **Consapevolezza…** per impostare o correggere l'istante (ogni modifica resta nel registro di audit); **Valutazione…** per registrare il livello di rischio (improbabile, rischio, elevato), motivazione, conseguenze probabili, numero approssimativo di interessati, categorie di dati coinvolte, e le due decisioni (notificare al Garante? comunicare agli interessati?) con l'eventuale motivo di un ritardo; **Registra azione…** per ciò che si fa (contenimento, notifica, integrazione, comunicazione agli interessati,

note).

4. L'azione di tipo **Notifica al Garante** richiede il **numero di protocollo o la ricevuta**, da inserire **dopo** l'invio effettivo: il programma non registra una notifica che non è avvenuta.
5. **Chiudi incidente** quando tutto è documentato.

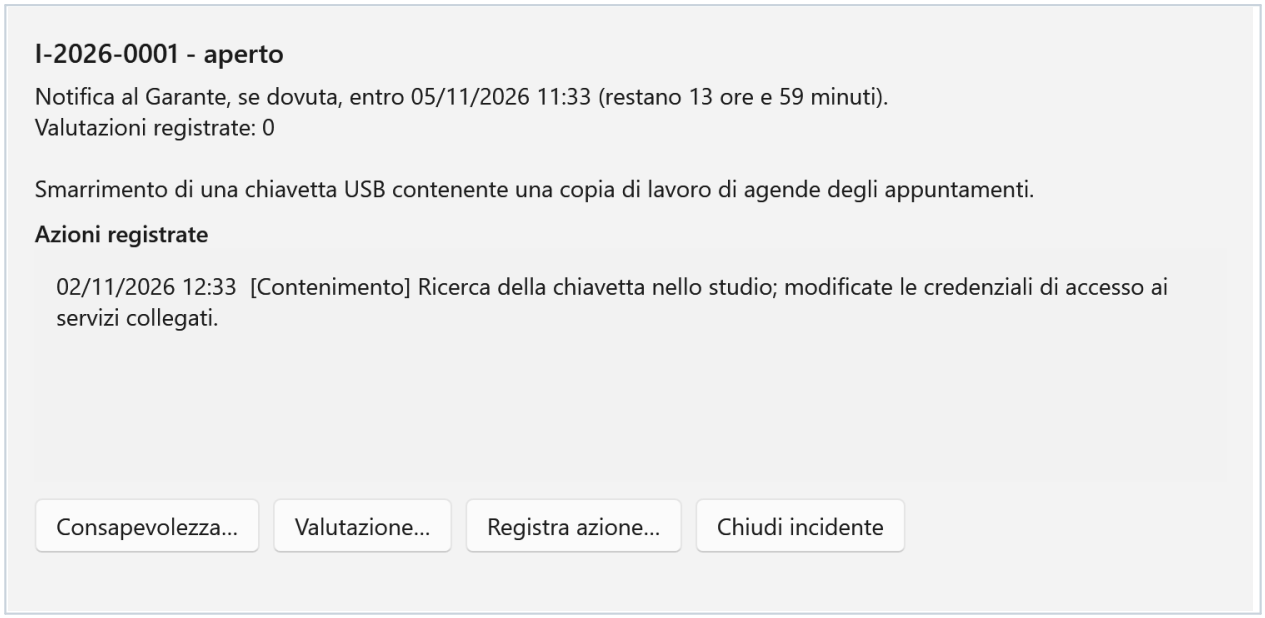


***Figura 19** - Dettaglio di un incidente: scadenza di notifica, azioni registrate e comandi (Consapevolezza, Valutazione, Registra azione, Chiudi).*

ATTENZIONE

Il programma **non invia** la notifica al Garante e **non decide** se un evento sia una violazione né se vada notificata. Il medico (con il consulente, nei casi dubbi) valuta; il programma ricorda l'orologio e conserva la documentazione. Anche le violazioni **non** notificate vanno registrate: l'art. 33, par. 5 lo richiede.

DA ESAMINARE

Quando decorrono le 72 ore. Il Regolamento parla del momento in cui il titolare "ne è venuto a conoscenza"; le linee guida dell'EDPB lo collegano al momento in cui il titolare ha un ragionevole grado di certezza che si sia verificata una violazione. Quale istante inserire come "consapevolezza" in un caso concreto è una valutazione da fare con attenzione.
Come si notifica al Garante. Esiste una procedura telematica messa a disposizione dal Garante: le modalità vigenti e i campi richiesti vanno verificati sul sito dell'autorità al momento dell'uso. Il programma conserva solo il protocollo.
Classificazione e soglie di rischio (quando il rischio è "improbabile", "presente", "elevato"): scelta del titolare, anche con riferimento alle linee guida dell'EDPB.

6.7 Conservazione e eliminazione

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 5, par. 1, lett. e); art. 13, par. 2, lett. a); art. 30, par. 1, lett. f)

I dati personali sono conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo **non superiore al conseguimento delle finalità** per le quali sono trattati. Il titolare deve poter indicare i termini di cancellazione e informare gli interessati del periodo di conservazione o dei criteri per determinarlo.

Le regole di conservazione

Nella scheda **Conservazione** si definiscono le regole, una per tipo di documentazione. **Il programma non propone alcuna durata**: le sceglie il titolare. **Nuova regola…** chiede il tipo di documentazione (richieste degli interessati, incidenti, informative e prove di consegna, …), l'evento da cui decorre la durata (es. chiusura della richiesta), la natura della durata e il riesame della regola:

- **Determinata**: si indicano mesi e/o giorni. Alla data di scadenza gli elementi compaiono tra gli **elementi scaduti**.
- **Illimitata, motivata** o **a criterio**: serve un criterio o una motivazione scritta; non scade da sola e compare tra le **regole da rivedere** quando è passata la data di riesame. Una durata "vuota" non vale mai come "illimitata".

La regola nasce in **bozza** e non ha effetto finché il titolare non la **approva** (**Approva selezionata**). Una nuova versione di una regola sostituisce la precedente, che diventa "superata".

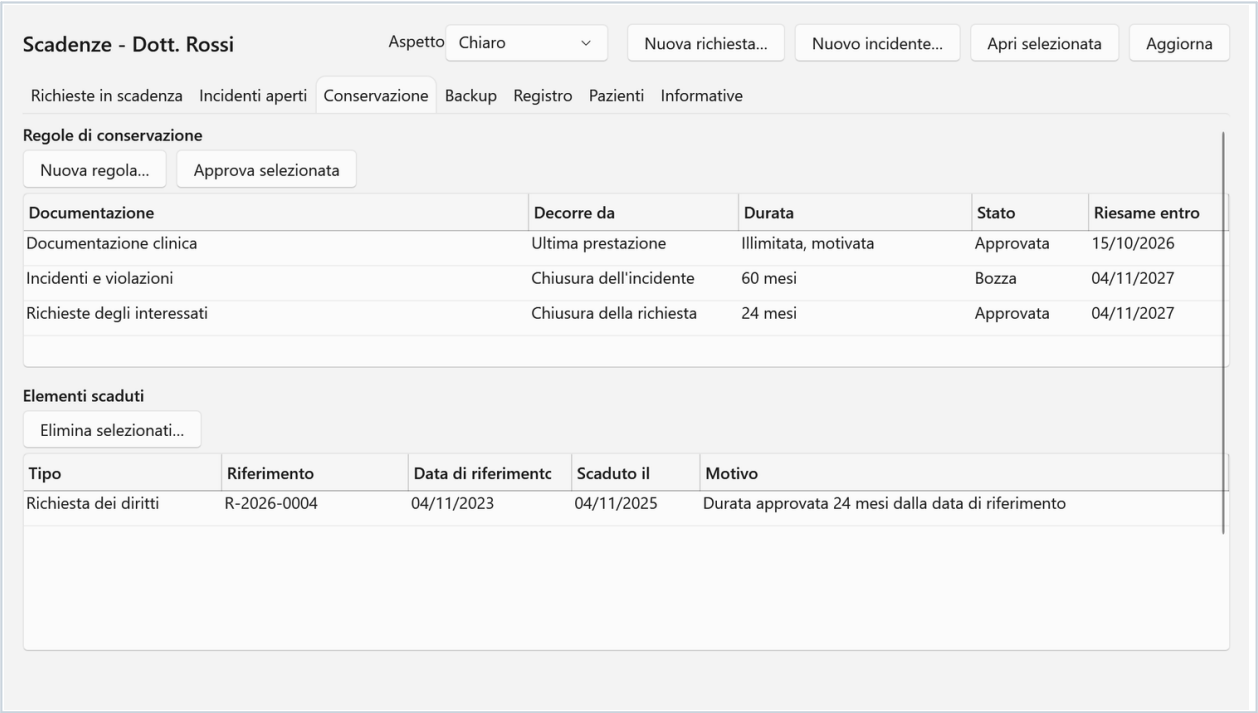


***Figura 20** - La scheda «Conservazione»: regole, elementi scaduti con il motivo e regole da rivedere. Le durate mostrate sono esempi inventati, non indicazioni.*

Eliminare gli elementi scaduti

1. Nella lista **Elementi scaduti** (richieste chiuse, incidenti chiusi, consegne di informative la cui durata approvata è trascorsa), selezionare uno o più elementi (tasto Ctrl per più righe).
2. **Elimina selezionati…**: il programma elenca gli elementi, chiede la **motivazione** (l'autorizzazione del titolare) e di digitare ELIMINA.
3. I dati vengono cancellati dal database (con i file collegati svuotati). Restano solo il **registro dell'eliminazione** (descrizione generica e identificativo dell'elemento, senza dati personali) e la riga di audit.
4. L'identificativo viene scritto anche in un **file esterno** (`ledgerPath`), copiato con ogni backup: serve, dopo un ripristino da un backup più vecchio, a rieliminare ciò che era già stato cancellato (§ 7.4).

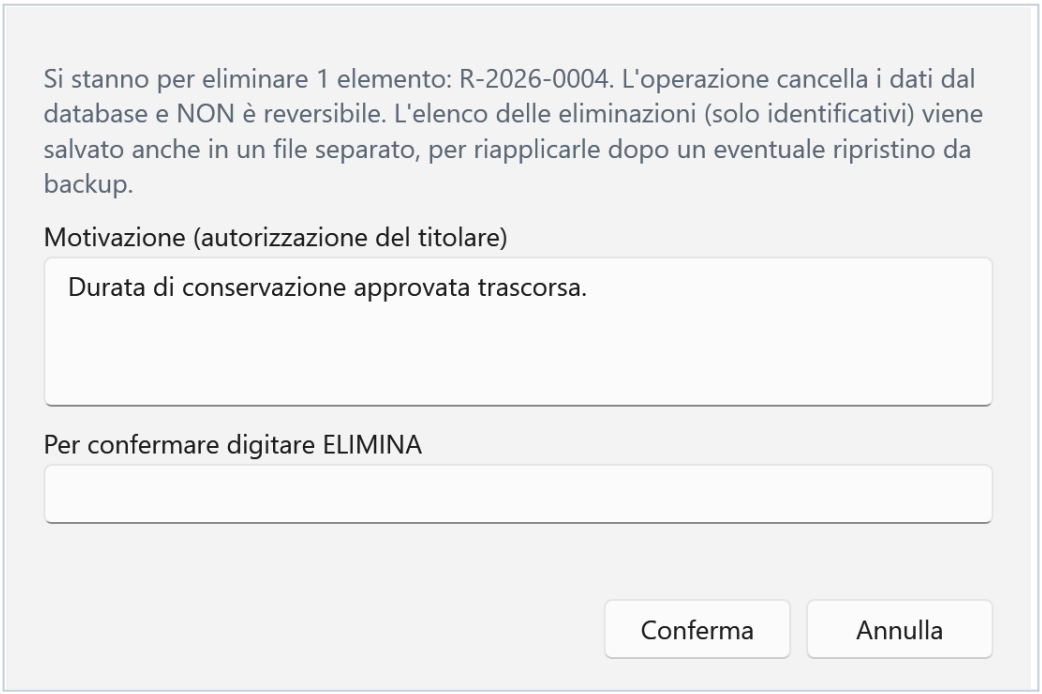


***Figura 21** - Eliminazione guidata: elenco degli elementi, motivazione e conferma scritta.*

ATTENZIONE

L'eliminazione è **irreversibile**. Richieste e incidenti si possono eliminare solo se chiusi. Il programma non cancella mai nulla da solo: ogni eliminazione richiede l'azione del titolare.

DA ESAMINARE

Durate di conservazione. Per la **documentazione clinica** non esiste, per lo studio del singolo medico, un termine unico e semplice: la prassi per le cartelle cliniche delle strutture sanitarie si richiama a indicazioni ministeriali che portano a una conservazione molto lunga o illimitata, mentre per lo studio professionale la durata va stabilita tenendo conto di obblighi di legge, esigenze di difesa in giudizio, indicazioni dell'Ordine e delle regole regionali. **Da definire con il consulente.** La documentazione clinica non è comunque gestita da questo programma.
Documenti contabili e fiscali: scritture contabili (art. 2220 del codice civile, di regola dieci anni) e documenti fiscali seguono la normativa tributaria; il termine esatto per ciascun documento è da confermare con il commercialista.
Richieste e incidenti: per quanto tempo conservare le richieste chiuse e la documentazione delle violazioni (che serve anche a dimostrare la conformità) è una scelta del titolare, da motivare.
Il **registro di audit** e il **registro delle eliminazioni** non vengono eliminati dal programma; la loro durata di conservazione va decisa a parte.

6.8 Backup e chiavi

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 32, par. 1, lett. c) e d)

Le misure di sicurezza comprendono la capacità di ripristinare tempestivamente la disponibilità e l'accesso ai dati personali in caso di incidente fisico o tecnico, e una procedura per provare regolarmente l'efficacia delle misure.

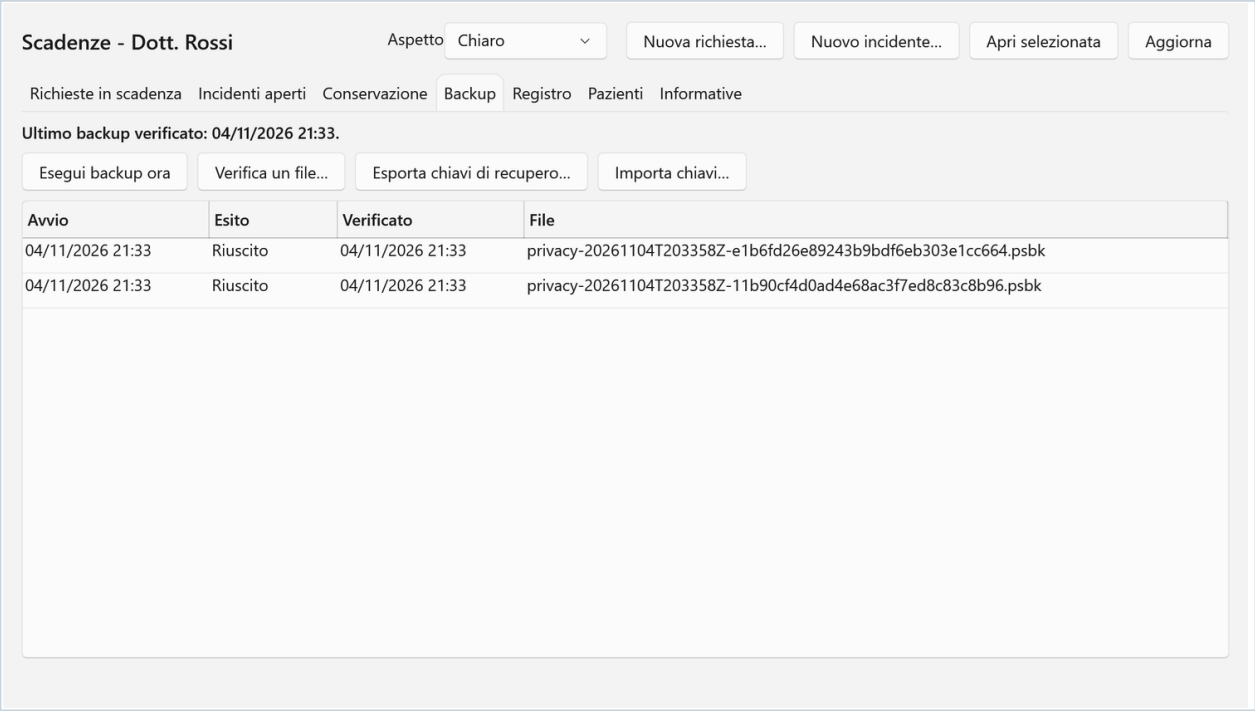


***Figura 22** - La scheda «Backup»: stato rispetto all'obiettivo di 24 ore, esecuzioni e comandi per le chiavi.*

- **Esegui backup ora**: il programma estrae una copia dei dati, la **cifra**, la scrive nella cartella dei backup e nella copia esterna, poi la **rilegge e la decifra dal disco** per accertarsi che sia valida. Solo allora l'esecuzione risulta **Riuscita** con la data di verifica. Accanto alla copia viene messo il file con l'elenco delle eliminazioni.
- In cima alla scheda una riga indica lo stato rispetto all'obiettivo di **24 ore** (*ATTENZIONE: l'ultimo backup verificato risale a… ore fa*).
- **Verifica un file…**: controlla a campione che un file di backup si decifri e sia una copia valida.
- **Esporta / Importa chiavi…**: vedi § 5.3.

DA ESAMINARE

Frequenza e tempi di ripristino. L'obiettivo di 24 ore di perdita massima di dati e di un giorno lavorativo per il ripristino è una **proposta** da confermare con il medico: non sono termini fissati dal Regolamento.
Il **backup è manuale**: non c'è ancora la pianificazione automatica. Va fatto a fine giornata e controllato.
Il file di backup è trattato in memoria durante la cifratura: adatto alle dimensioni di uno studio, non a volumi molto grandi.

7. Procedure operative

7.1 Che cosa fare, e quando

Le cadenze sono **proposte**, da adattare all'organizzazione dello studio.

Quando	Che cosa	Dove
Ogni giorno	Guardare le schede **Richieste in scadenza** e **Incidenti aperti**. Registrare le richieste ricevute il giorno stesso. A fine giornata: **Esegui backup ora** e controllare che sia "Riuscito".	§ 6.5, 6.6, 6.8
Per ogni nuovo paziente	Consegnare l'informativa e registrare la consegna (anche "senza firma").	§ 6.3
Ogni settimana	Controllare che i file di backup siano presenti anche nella copia esterna; **Verifica un file…** su uno di essi.	§ 6.8
Ogni mese	Guardare gli **elementi scaduti** nella scheda Conservazione e, se il titolare lo decide, eliminarli. Controllare le attività con riesame scaduto nel Registro.	§ 6.4, 6.7
Ogni sei mesi	**Prova di ripristino** su un computer diverso, con la sola copia esterna e il file delle chiavi di recupero.	§ 7.4
Ogni anno	Riesaminare il registro, le informative, le regole di conservazione, l'elenco dei fornitori e delle persone autorizzate; formare chi lavora nello studio.	Cap. 8
Quando cambia qualcosa	Nuovo trattamento, nuovo fornitore, cambio di sede o di software: aggiornare il Registro (nuova revisione) e valutare se l'informativa va rivista.	§ 6.4

7.2 Una richiesta di un paziente, dall'inizio alla fine

1. Il paziente chiede, per email, copia dei propri dati. Lo stesso giorno: **Nuova richiesta…**, qualità "Interessato", canale "Email", diritto "Accesso". Annotare il riferimento assegnato.
2. Verificare che si tratti davvero della persona (se c'è un dubbio ragionevole, chiedere informazioni supplementari: art. 12, par. 6) e annotarlo nella cronologia o a parte.
3. Preparare il riscontro fuori dal programma (copia dei dati, informazioni richieste dall'art. 15).
4. Se serve più tempo per complessità, **prima della scadenza** usare **Proroga…** con la motivazione e comunicarla al paziente entro un mese dalla richiesta.
5. Inviato il riscontro: **Decisione…** per il diritto, esito "Accolta" (o altro con motivazione), indicando la data di invio.
6. **Chiudi richiesta**. Il programma conserva cronologia, scadenza iniziale ed eventuale proroga.

7.3 Una violazione dei dati, dalla scoperta alla chiusura

> **ATTENZIONE**
> Il tempo conta: le 72 ore decorrono da quando il titolare ne viene a conoscenza. Annotare subito, anche su carta, **data e ora** in cui si è capito che qualcosa è successo.

1. **Contenere**: scollegare il computer dalla rete, cambiare le password, bloccare l'account compromesso, recuperare il dispositivo se smarrito. Non cancellare tracce utili.

2. **Registrare**: **Nuovo incidente…** con data e ora di rilevazione, descrizione e, se già accertata, la consapevolezza. L'orologio delle 72 ore compare in **Incidenti aperti**.
3. **Valutare**: **Valutazione…**. Che dati sono coinvolti? Quante persone? Con quali conseguenze probabili? Il rischio per i diritti e le libertà è improbabile, presente, elevato? Nei casi dubbi, sentire il consulente.
4. **Decidere** e registrare: notificare al Garante? comunicare agli interessati? Se si decide di non notificare, scrivere perché (art. 33, par. 5).
5. **Notificare**, se dovuto, attraverso la procedura messa a disposizione dal Garante, entro le 72 ore (altrimenti con i motivi del ritardo). Poi **Registra azione…** di tipo "Notifica al Garante" con il **numero di protocollo o la ricevuta**.
6. **Comunicare agli interessati**, se il rischio è elevato e non ricorre un'eccezione; registrare l'azione.
7. **Rimediare e chiudere**: registrare le azioni correttive, rivedere le misure di sicurezza, poi **Chiudi incidente**.

7.4 Ripristino dopo un guasto o su un nuovo computer

> **ATTENZIONE**
> Il ripristino va **provato prima** di averne bisogno (ogni sei mesi, § 7.1). Un backup mai ripristinato è una speranza, non una garanzia. Finora è stato provato solo con un database di prova in ambiente di sviluppo, **non su un computer Windows pulito** (punto 16 del cap. 9).

Il ripristino crea sempre un database **nuovo**: non sovrascrive mai uno esistente. Servono: il file di backup (`.psbk`) con il suo file dell'elenco eliminazioni (`.ledger.jsonl`), il file delle chiavi di recupero con la sua frase, PostgreSQL e il programma installati sul nuovo computer.

1. Installare PostgreSQL e il programma (cap. 4) **senza creare lo schema**; indicare `pgBinDir` in `config.json`.
2. Reinstallare le chiavi: **Importa chiavi…** (§ 5.3). Senza le chiavi il file non si apre.
3. Copiare in una cartella il backup e il suo `.ledger.jsonl`.
4. Da un terminale, con la stringa dell'amministratore del database nella variabile d'ambiente (non sulla riga di comando):

```
set PRIVACY_ADMIN_CONN=Host=127.0.0.1;Port=5432;Database=postgres;
Username=postgres;Password=...   (tutto su una riga)
Privacy.App.exe --restore "D:\Ripristino\privacy-....psbk" --database privacy
```

Il programma, in quest'ordine: verifica che il file si decifri; crea il database e i ruoli; ripristina i dati; **rielimina ciò che il backup aveva riportato** usando l'elenco delle eliminazioni; controlla la catena del registro di audit; registra la prova di ripristino. Alla fine mostra un riepilogo. L'esito è pieno solo se la catena è integra, non ci sono eliminazioni da verificare a mano e l'elenco delle eliminazioni è stato fornito.

1. Impostare le password dei ruoli `privacy_app` e `privacy_migrator` (non sono nel backup) e aggiornare `connection.txt` perché punti al nuovo database.
2. Accedere e controllare i dati. **Non riprendere l'attività normale** finché il riepilogo non è pulito.

> **ATTENZIONE**
> Se l'elenco delle eliminazioni non è stato fornito, i dati cancellati dopo la data del backup possono essere di nuovo visibili. Recuperare il file più recente ed eseguire `Privacy.App.exe --reapply-disposals` **prima** di riprendere l'uso.

8. Sicurezza e responsabilità

8.1 Che cosa fa il programma per la sicurezza

Misura	Come è realizzata	Esigenza (art. 32)
Accesso controllato	Password con derivazione PBKDF2-SHA256 (600.000 iterazioni, sale casuale); blocco dopo 5 tentativi per 15 minuti, che resiste al riavvio; messaggi uniformi.	Riservatezza
Separazione dei ruoli del database	Il ruolo operativo non può modificare la struttura né alterare audit, versioni pubblicate ed eventi.	Riservatezza, integrità
Registro di audit a catena	Ogni operazione importante è registrata e legata alla precedente da un codice di controllo; modifiche o cancellazioni successive si rilevano. La catena è verificata a ogni ripristino.	Integrità
Versioni immutabili	Registro e informative pubblicati, consegne e prove non si modificano; si crea una nuova versione.	Integrità
Backup cifrati e verificati	AES-256-GCM; file riletto e decifrato dal disco; copia esterna; elenco delle eliminazioni riapplicabile.	Disponibilità, ripristino
Moduli con impronta con chiave	Codice di controllo HMAC-SHA256 del modulo consegnato, per dimostrare che non è stato alterato.	Integrità
Dati ridotti al minimo	Nessun dato clinico; nei file non si conserva il nome originale.	Minimizzazione (art. 5)
Errori e registri senza dati	Gli errori tecnici non mostrano dettagli; le password non compaiono mai in audit o messaggi.	Riservatezza

8.2 Limiti dichiarati

- L'amministratore del database e il ruolo proprietario possono aggirare le protezioni applicative: è un limite di qualunque sistema, mitigato dalla separazione dei ruoli e dal registro di audit. Chi ha quei poteri va individuato e vincolato (nomina, cap. 3).
- Le chiavi sono custodite da Windows (DPAPI) per l'utente che lavora: protette da chi non conosce la sua password, **non** da chi la conosce. Vedi § 9, punto 1.
- La password del database sta in un file dell'utente (§ 4.4). L'elenco esterno delle eliminazioni non è cifrato né firmato (contiene solo identificativi).
- Non esiste ancora una schermata per consultare il registro di audit; la verifica della catena avviene al ripristino.
- Il programma non è progettato per inviare dati all'esterno; l'**assenza** di connessioni in uscita e l'inaccessibilità del database dalla rete **non sono ancora state verificate con una prova automatica**.

8.3 Che cosa resta al titolare

Adempimento	Riferimento	Nel programma?
Designare e istruire le persone autorizzate (segretaria, collaboratori)	Art. 29 GDPR; art. 2-quaterdecies Codice	No
Nominare i responsabili del trattamento (informatico, hosting, commercialista, laboratori, …)	Art. 28 GDPR	No (previsto)
Valutare se servono DPO e valutazione d'impatto	Artt. 35, 37 GDPR	No
Verificare e rivedere le misure di sicurezza dello studio	Art. 32 GDPR	In parte (backup, accesso)
Redigere e approvare l'informativa	Artt. 12-14 GDPR	Schema e pubblicazione
Gestire consensi e revoche per finalità diverse dalla cura	Art. 6, par. 1, lett. a); art. 7	No (previsto)
Tenere la documentazione clinica e stabilirne la conservazione	Obblighi professionali e art. 5	No
Formare chi lavora nello studio	Art. 29, art. 32, par. 4	No

RIFERIMENTO NORMATIVO - Reg. UE 2016/679, art. 32, par. 4 e art. 29

Il titolare del trattamento e il responsabile del trattamento fanno sì che chiunque agisca sotto la loro autorità e abbia accesso a dati personali non tratti tali dati se non è istruito in tal senso.

9. Punti da esaminare

Raccolta di tutti i punti segnalati nel manuale come incerti o rimessi a una scelta. Per ciascuno è indicato **chi dovrebbe decidere**. Le norme citate vanno controllate nel testo vigente al momento dell'uso. Questa tabella è il primo documento da portare al consulente.

N.	Argomento	Perché è da esaminare	Chi decide	Rif.
1	Protezione di chiavi, database e credenziali	Le chiavi sono custodite da Windows per l'utente; la password del database è in un file. Manca una scelta definitiva fra cifratura del disco, cifratura dei campi e gestione delle chiavi, con una procedura di recupero provata da una persona non tecnica.	Medico con esperto di sicurezza	§ 4.4, 5.3
2	Calcolo dei termini e proroga	Applicazione del Reg. 1182/71 al termine dell'art. 12 GDPR; slittamento a giorno lavorativo; proroga massima di tre mesi complessivi oppure uno più due.	Consulente	§ 6.5, App. B
3	DPO e valutazione d'impatto	Per il singolo professionista sanitario di norma non obbligatori (considerando 91; FAQ del Garante), ma dipende da organizzazione e dimensioni dello studio.	Consulente	§ 2.3
4	Consensi per finalità diverse dalla cura	Marketing, ricerca, fascicolo sanitario ecc.: quali trattamenti dello studio li richiedono; la gestione non è nel programma.	Consulente	§ 2.2
5	Testo dell'informativa	Il programma fornisce solo uno schema. Contenuto e completezza sono del titolare; eventuale norma specifica per medici di base e pediatri (art. 78 Codice).	Medico, consulente	§ 6.3
6	Durate di conservazione	Documentazione clinica (non gestita dal programma), documenti fiscali (art. 2220 c.c. e normativa tributaria), richieste, incidenti, audit.	Medico, consulente, commercialista	§ 6.7
7	Rappresentanti legali e minori	Come documentare i poteri di chi ritira per un minore o una persona sotto tutela; la schermata non esiste ancora.	Consulente	§ 6.3
8	Accesso alla documentazione sanitaria	Termini specifici della L. 24/2017, art. 4, e rapporto con l'art. 12 GDPR per lo studio individuale.	Consulente	§ 6.5
9	Persone autorizzate e responsabili	Come formalizzare l'assistenza informatica e gli altri fornitori; chi accede ai dati e a che titolo.	Medico, consulente	§ 3.3, 8.3
10	Verifica dell'identità del richiedente	Art. 12, par. 6: non registrata nell'interfaccia; come documentarla.	Medico	§ 6.5
11	Consapevolezza e notifica delle violazioni	Quale istante contare come "conoscenza"; modalità vigenti della procedura telematica del Garante; soglie di rischio.	Medico, consulente	§ 6.6
12	Completezza del registro (art. 30)	Mancano nell'editor sistemi, misure per attività, fornitori, trasferimenti verso paesi terzi.	Medico	§ 6.4

N.	Argomento	Perché è da esaminare	Chi decide	Rif.
13	Misure di garanzia per dati sanitari	L'art. 2-septies del Codice prevede misure di garanzia per i dati relativi alla salute da adottare con provvedimento del Garante: stato e contenuto vigenti da verificare.	Consulente	§ 2.1
14	Obiettivi di backup	Perdita massima di 24 ore e ripristino in un giorno lavorativo sono proposte, non obblighi.	Medico	§ 6.8
15	Aggiornamento del programma	Procedura per applicare nuove versioni dello schema, con copia di sicurezza prima, da scrivere e provare.	Sviluppo, medico	§ 4.3
16	Installazione e ripristino su Windows pulito	Il programma di installazione è solo in bozza: provato in "prova a secco", non con l'installazione reale di PostgreSQL; il ripristino è provato in ambiente di sviluppo.	Sviluppo	§ 4, 7.4
17	Tema dell'interfaccia	Basato su una funzione sperimentale di .NET 10; provato su Windows 11, non su Windows 10, scale diverse dal 100% e contrasto elevato.	Sviluppo	§ 6.1
18	Firma digitale dell'installatore	Senza certificato di firma Windows mostra l'avviso "editore sconosciuto". Decisione rimandata.	Medico	§ 4.0
19	Ruolo del medico in strutture, associazioni e piattaforme	Titolare autonomo, contitolare, responsabile o persona autorizzata: dipende da contratti e organizzazione.	Consulente	§ 0.1
20	Trasferimenti fuori dall'Unione per servizi in cloud	Validità delle decisioni di adeguatezza e delle garanzie contrattuali per ogni servizio con dati sanitari.	Consulente	§ 0.3.7
21	Telemedicina, FSE, videosorveglianza, sito web	Regole specifiche e possibile DPIA, non coperte dal programma.	Consulente	§ 0.3.11-12

10. Stato delle funzioni e condizioni di rilascio

10.1 Che cosa è disponibile oggi

Funzione	Disponibile	Non ancora disponibile
F01 Registro	Attività, revisioni, finalità e basi giuridiche, categorie, pubblicazione con controlli, esportazione alla data.	Sistemi, misure per attività, fornitori, trasferimenti; conservazione per finalità nell'esportazione.
F02 Informative e consegne	Informative con variabili, pubblicazione, consegna e storico, verifica dell'integrità del modulo.	Stampa e PDF; acquisizione della scansione della ricevuta firmata; rappresentanti legali.
F03 Richieste	Registrazione, scadenza, proroga, decisione, chiusura, anche da non pazienti.	Verifica dell'identità; collegamento alla scheda del paziente; allegati.
F04 Violazioni	Registrazione, orologio delle 72 ore, valutazione, azioni, protocollo di notifica, chiusura.	Allegati e prove; rilettura delle valutazioni nel dettaglio.
F05 Conservazione	Regole con approvazione, elenco degli scaduti con motivo, eliminazione guidata, registro riapplicabile.	Documentazione clinica (fuori dal programma).
F06 Backup e ripristino	Backup cifrato verificato con copia esterna; verifica file; chiavi di recupero; ripristino da riga di comando; riapplicazione eliminazioni.	Pianificazione automatica; prova su Windows pulito.
F07 Rimozione interessato	Rimozione con anonimizzazione delle prove di consegna.	—
Accesso	Accesso con password, blocco persistente, audit.	Cambio password in interfaccia; scadenza della sessione; più utenti e ruoli.
Installazione	Prima configurazione guidata; script del database; programma di installazione con PostgreSQL incluso (bozza).	Prova dell'installatore su Windows pulito; firma digitale; aggiornamenti automatici; modifica dei dati dello studio.

10.2 Condizioni prima di usare dati reali

Condizioni di progetto basate sul rischio (non un certificato di conformità). Se una non è soddisfatta, si continua a provare con dati inventati.

1. Configurazione effettiva dello studio e dei destinatari/fornitori.
2. Informative approvate dal titolare (e, se coinvolto, dal consulente).
3. Durate e regole di conservazione decise e registrate.
4. Regola dei termini confermata dal consulente.
5. Decisione sulla protezione di chiavi e database presa e rischio residuo registrato (punto 1 del cap. 9).
6. Prova dei permessi del database e della catena di audit; ripristino riuscito su una macchina pulita, con le chiavi di recupero consegnate e verificate.
7. Procedura per le violazioni scritta e provata con un caso simulato.
8. Responsabilità di manutenzione e aggiornamenti assegnate, compresa la nomina di chi può accedere ai dati.

Appendice A - Glossario

Termine	Significato
Titolare del trattamento	Chi decide finalità e mezzi del trattamento: qui il medico o lo studio (art. 4, n. 7).
Interessato	La persona a cui i dati si riferiscono: il paziente, ma anche un collaboratore o un fornitore.
Dati relativi alla salute	Dati sulla salute fisica o mentale, anche relativi alla prestazione di servizi sanitari (art. 4, n. 15). Categoria particolare (art. 9).
Responsabile del trattamento	Chi tratta dati per conto del titolare (art. 28): per esempio il fornitore informatico.
Persona autorizzata	Chi tratta dati sotto l'autorità del titolare (art. 29; art. 2-quaterdecies del Codice).
DPO / RPD	Responsabile della protezione dei dati (artt. 37-39), nominato nei casi previsti.
DPIA	Valutazione d'impatto sulla protezione dei dati (art. 35).
Violazione dei dati	Violazione di sicurezza che comporta, anche accidentalmente, distruzione, perdita, modifica, divulgazione o accesso non autorizzati (art. 4, n. 12).
Base giuridica	La ragione per cui un trattamento è lecito (art. 6; per i dati sulla salute anche art. 9).
Informativa	Il documento con cui si informa l'interessato su come sono trattati i suoi dati (artt. 13-14).
Garante	Autorità garante per la protezione dei dati personali.
EDPB	Comitato europeo per la protezione dei dati, che emana linee guida.
Revisione	Versione numerata di un'attività del registro o di un documento. Una volta pubblicata non si modifica.
Registro di audit	Elenco delle operazioni, legate l'una all'altra da un codice di controllo, in modo che ogni manomissione si noti.
HMAC	Codice di controllo calcolato con una chiave segreta: permette di verificare che un testo non sia cambiato.
Backup cifrato	Copia dei dati resa illeggibile senza la chiave (AES-256-GCM).
Elenco delle eliminazioni	File esterno con tipo e identificativo di ciò che è stato eliminato, per rieliminarlo dopo un ripristino.

Appendice B - Esempi di calcolo dei termini

Regola `it-1182-v1` (da confermare, § 6.5): il giorno di ricezione non conta; scadenza nel giorno corrispondente del mese successivo; se manca, ultimo giorno del mese; se cade di sabato, domenica o festività nazionale, primo giorno lavorativo successivo. Festività considerate: 1 gennaio, 6 gennaio, lunedì di Pasqua, 25 aprile, 1 maggio, 2 giugno, 15 agosto, 1 novembre, 8 dicembre, 25 e 26 dicembre (più eventuali festività locali inserite dallo studio).

Ricevuta il	Scadenza	Motivo
lunedì 16/03/2026	giovedì 16/04/2026	Caso ordinario.
sabato 31/01/2026	lunedì 02/03/2026	Il 28/02/2026 è sabato: slitta al primo giorno lavorativo.
lunedì 31/01/2028 (anno bisestile)	martedì 29/02/2028	Il giorno corrispondente non esiste: ultimo giorno del mese.
lunedì 30/11/2026	mercoledì 30/12/2026	Mese con meno giorni.
giovedì 31/12/2026	lunedì 01/02/2027	Il 31/01/2027 è domenica.
giovedì 15/10/2026	lunedì 16/11/2026	Il 15/11/2026 è domenica.
martedì 25/03/2025	lunedì 28/04/2025	Il 25/04 è festivo, il 26 e 27 sono sabato e domenica.
sabato 31/01/2026 con proroga massima	giovedì 30/04/2026	Tre mesi complessivi dalla ricezione, con la stessa regola (punto 2 del cap. 9).

CONSIGLIO

Finché la regola non è confermata dal consulente, rispondere **prima** della scadenza mostrata: nessuna delle interpretazioni plausibili è più favorevole al ritardo.

Appendice C - Lista di controllo per l'avvio

	Voce	Fatto il / da
[ ]	Computer dedicato, aggiornato, disco cifrato, account personale, blocco schermo automatico	
[ ]	PostgreSQL installato, in ascolto solo su localhost, firewall senza regola per la porta 5432	
[ ]	Database e ruoli creati, script 000-004 eseguiti senza errori, password dei ruoli annotate	
[ ]	`connection.txt` e `config.json` configurati (copia esterna su supporto diverso)	
[ ]	Prima configurazione dello studio completata; accesso riuscito	
[ ]	Chiavi di recupero esportate, file e frase conservati fuori dal PC e separatamente	
[ ]	Primo backup riuscito e verificato, presente anche nella copia esterna	
[ ]	Prova di ripristino su un altro computer eseguita e registrata	
[ ]	Registro: attività principali pubblicate	
[ ]	Informativa completata, approvata e pubblicata	
[ ]	Regole di conservazione decise e approvate	
[ ]	Persone autorizzate designate; fornitori nominati responsabili	
[ ]	Procedura per le violazioni letta da tutti e provata con un caso simulato	
[ ]	Punti del cap. 9 portati al consulente e risolti o accettati con rischio registrato	

Appendice D - Riferimenti normativi e documenti

Norme citate

- **Regolamento (UE) 2016/679**: artt. 4, 5, 6, 7, 9, 12, 13, 14, 15, 16, 17, 18, 20, 21, 24, 28, 29, 30, 32, 33, 34, 35, 37 e considerando 91.
- **D.Lgs. 30 giugno 2003, n. 196** (Codice in materia di protezione dei dati personali), come modificato dal **D.Lgs. 10 agosto 2018, n. 101**: artt. 2-terdecies, 2-quaterdecies, 2-septies; Parte II, Titolo V (artt. 75 e seguenti), in particolare art. 78.
- **Regolamento (CEE, Euratom) n. 1182/71** del Consiglio, sulle norme applicabili ai periodi di tempo, alle date e ai termini.
- **Legge 8 marzo 2017, n. 24**, art. 4 (trasparenza dei dati sanitari).
- **Codice civile**, art. 2220 (conservazione delle scritture contabili).
- **Provvedimento del Garante del 7 marzo 2019**, sul trattamento dei dati relativi alla salute in ambito sanitario; **FAQ del Garante** sul responsabile della protezione dei dati in ambito sanitario; **linee guida dell'EDPB** sulla notifica delle violazioni dei dati personali.

DA ESAMINARE

L'elenco è quello dei riferimenti usati per costruire il programma e il manuale. Il testo, i numeri e la vigenza dei provvedimenti vanno **controllati alla fonte ufficiale** (Gazzetta Ufficiale, EUR-Lex, sito del Garante, sito dell'EDPB) prima di fondarci decisioni.

Documenti tecnici del progetto

Documento	Contenuto
01 - Analisi normativa	Obblighi, loro classificazione (obbligo di legge, scelta di progetto, decisione del titolare), decisioni aperte.
02 - Specifica funzionale e dati	Flussi F01-F07, struttura dei dati, regole del database.
03 - Piano di test e rilascio	Prove eseguite e da eseguire; condizioni di rilascio con dati reali.
04 - Procedura di backup e ripristino	Dettaglio tecnico di backup, chiavi e ripristino.

Registro delle modifiche del manuale

Versione	Data	Modifica
0.9	novembre 2026	Prima stesura, bozza per revisione. Riferita al programma in pre-rilascio.